INTERNSHIP PROJECT REPORT

(Information Gathering & Enumeration Report)

Organization

ITSOLERA Pvt. Ltd

Department

Offensive Security

Group/Team

Team Alpha

Date: March 18, 2026

TABLE OF CONTENTS

1. Executive Summary **3**
2. Legal & Ethical Compliance **3**
3. Assignment Objective **4**
4. Engagement Scope **4**
5. Methodology Overview **5**
6. Target Selection **6**
7. Assignment Tasks **7**
7.1. Task 1: Understanding the Reconnaissance Phase (Theory) 7
7.1.1. Passive vs Active Reconnaissance 7
7.1.2. Why Reconnaissance is Critical in the Cyber Kill Chain 7
7.1.3. How Attackers Misuse It in Real-World Attacks 7
7.1.4. How Ethical Hackers Use It Defensively 7
7.2. Task 2: Google Dorking Investigation 8
7.2.1. Public documents (PDF, DOC, XLS) 8
7.2.2. Finding Login/Signup portals 10
7.2.3. Identifying Email Formats 11
7.2.4. Discovering Subdomains 12
7.2.5. Finding Exposed Directories 12
7.2.6. Publicly Available Sensitive Information 13
7.3. Task 3: Metadata Analysis (YouTube / Documents) 14
7.3.1. Youtube Video Metadata Analysis 15
7.3.1.1. Document Metadata Analysis 17
7.4. Task 4: Shodan Intelligence Gathering 19
7.4.1. Gathering Public IP details 19
7.4.2. Searching for Open ports 20
7.4.3. Looking for Running Services 22
7.4.4. Website Technologies 23
7.4.5. Possible exposed systems 24
7.5. Task 5: Netcraft Tools Analysis 24
7.6. Task 6: FTP Intelligence (NAPALM FTP Indexer) 26
7.7. Task 7: Pentest Tool Recon Data 28
7.7.1. Performing a Subdomain Finder Scan 28
7.7.2. Performing a Website Recon Scan 31
7.8. Task 8: Email Infrastructure Analysis 33
7.9. Task 9: Mapping to Cyber Kill Chain 34
7.10. Task 10: Security Perspective (Defensive Thinking) 35
7.10.1. How Organizations Can Reduce OSINT Exposure 35
7.10.2. How CIA Triad Relates to Reconnaissance Risks 35

7.10.3. Controls to Prevent Intelligence Leakage..... 35
8. Learning Reflection..... 36
8.1. What I Learned from This Assignment..... 36
8.2. Reconnaissance Builds Foundation of Penetration Testing..... 36
8.3. How I Will Use These Skills as a Cybersecurity Professional..... 36

1. Executive Summary

This report presents a structured passive reconnaissance investigation conducted on a publicly accessible organization. The objective of this assessment was to simulate the reconnaissance phase of the Cyber Kill Chain using strictly passive Open-Source Intelligence (OSINT) techniques.

No direct interaction, scanning, exploitation, or intrusion was performed against the target infrastructure. All findings were collected using publicly available information sources.

This report demonstrates practical understanding of reconnaissance methodology, analytical investigation skills, and defensive security thinking aligned with professional penetration testing standards.

2. Legal & Ethical Compliance

This assessment was conducted under academic simulation conditions. The following principles were strictly followed:

- Only passive reconnaissance techniques were used
- No unauthorized access attempts were made
- No scanning tools were used against live systems
- No exploitation or intrusion activities were performed
- No data was modified, deleted, or interfered with
- All collected information was publicly accessible
- This report is created strictly for educational purposes.

3. Assignment Objective

The objective of this assignment is to:

- Develop practical understanding of passive reconnaissance
- Apply Open Source Intelligence (OSINT) investigation techniques
- Understand the Reconnaissance Phase of the Cyber Kill Chain (CKC)
- Analyze publicly exposed digital footprints of the Target
- Strengthen technical documentation and reporting skills
- Think from both attacker and defender perspectives

4. Engagement Scope

Here is what is ***included*** in Scope:

- Publicly available information
- Search engine intelligence
- Metadata analysis of Objects
- Public infrastructure information
- Technology stack identification
- Email infrastructure research

Here is what is ***excluded*** from Scope:

- Active scanning & Interaction
- Port scanning using intrusive tools
- Vulnerability Exploitation
- Brute-Force/Dictionary attacks
- Social engineering (Phishing, etc)
- Direct interaction with the target’s systems

5. *Methodology Overview*

The reconnaissance methodology employed strictly passive OSINT techniques across seven tasks.

- For **Google Dorking**, I used advanced search operators (`site:`, `filetype:`, `inurl:`) on Google to uncover public documents, login portals, email patterns, subdomains, and exposed directories on au.edu.pk.
- **Metadata analysis** was performed using MW Metadata for YouTube videos and Exif.tools/Metadata2go for PDF documents to extract embedded author names, software versions, and creation dates.
- **Shodan intelligence** involved pinging the target for its public IP, then querying Shodan to identify 12 open ports and running services (cPanel, WHM, Webmail), supplemented by Wappalyzer for additional technology detection.
- **Netcraft** provided hosting details, SPF/DMARC status, and security headers through its site report tool. **FTP reconnaissance** used NAPALM FTP Indexer to check for exposed FTP servers (none found).
- Finally, **Pentest-Tools.com** automated subdomain discovery (51 subdomains found, 39 active) and website recon to map infrastructure and identify technologies like Plesk Obsidian. All findings were documented with screenshots for evidence.

Task	Tool Used	Why Used	Process Performed
Task 2: Google Dorking	Google Search	Find exposed documents, portals, and emails	Used advanced search operators (`site:`, `filetype:`, `inurl:`) to search `au.edu.pk` for PDFs, login pages, email addresses, subdomains, and exposed directories.
Task 3: Metadata Analysis	MW Metadata, Exif.tools	Extract hidden file information	Uploaded a YouTube video URL and a PDF document to extract metadata such as author names, software versions, creation dates, and embedded document details.
Task 4: Shodan Intelligence	Ping, Shodan, Wappalyzer	Identify open ports and services	Used Ping to determine the target IP address, searched the IP on Shodan to identify 12 open ports and associated services, and used Wappalyzer to detect additional technologies in use.
Task 5: Netcraft Analysis	Netcraft Site Report	Gather hosting and security configuration details	Entered the domain into Netcraft to retrieve hosting provider information, DNS records, SPF/DMARC status, and server-side technologies.

Task 6: FTP Intelligence	NAPALM FTP Indexer	Check for exposed FTP servers	Searched the domain name and associated IP addresses to identify any publicly accessible FTP directories or exposed files.
Task 7: Pentest Tools Scan	Pentest-Tools .com	Automated subdomain and technology discovery	Executed Subdomain Finder (51 subdomains discovered) and Website Recon scans to map infrastructure and identify underlying technologies.

6. Target Selection

I have selected **Air University, Pakistan** (*au.edu.pk*) as my target because it is a legitimate public sector educational institution, making it legally accessible for passive reconnaissance while offering a rich online footprint of subdomains, public documents, and staff information to analyze.

7. Assignment Tasks

7.1. Task 1: Understanding the Reconnaissance Phase (Theory)

Reconnaissance is the first phase of a cyber attack where an attacker gathers information about a target (such as systems, networks, employees, and vulnerabilities) before launching an attack. It is often called the “information gathering” or “footprinting” phase.

7.1.1. Passive vs Active Reconnaissance

- **Passive Reconnaissance:**
  - It means collecting information without directly interacting with the target.
  - For example by searching public websites, social media, WHOIS records, etc
  - It is very hard to detect and most of the time it goes un-noticed.
- **Active Reconnaissance:**
  - It means directly interacting with the target system.
  - For example by port scanning, ping sweeps, banner grabbing, etc.
  - It is easier to detect but provides more detailed information.

7.1.2. Why Reconnaissance is Critical in the Cyber Kill Chain

In the **Cyber Kill Chain (CKC)**, reconnaissance/footprinting is the foundation. The information gathered helps attackers identify weaknesses, choose attack methods, and increase the success rate of later stages like exploitation and installation.

7.1.3. How Attackers Misuse It in Real-World Attacks

Attackers use reconnaissance to:

- Identify vulnerable services and open ports
- Collect employee emails for phishing
- Map the network structures
- Find outdated software to exploit

This allows them to craft targeted attacks (e.g., spear-phishing or zero-day exploitation).

7.1.4. How Ethical Hackers Use It Defensively

Ethical hackers perform reconnaissance to:

- Discover any of the exposed assets

- Identify vulnerabilities before attackers
- Test the security posture of target
- Recommend security improvements

By doing this legally and with permission, they help organizations strengthen their defenses.

7.2. Task 2: Google Dorking Investigation

Google Dorking Investigation, also known as Google Hacking, involves using advanced Google search operators (or "dorks") to uncover sensitive, hidden, or unintentionally exposed information like passwords, databases, or confidential files indexed on the web. (GeeksforGeeks, 2025)

Cybersecurity professionals apply it ethically for reconnaissance and vulnerability assessments, while attackers exploit it for data leaks; making ethical use critical to avoid legal issues. (Danielson, 2025)

Examples include queries like site:example.com filetype:sql intext:password to probe specific sites for unsecured data dumps. Here are the searches I made for this task.

7.2.1. Public documents (PDF, DOC, XLS)

Google dorks like `site:universitydomain.edu filetype:pdf OR filetype:doc` can be used to search for publicly available university documents. These dorks can help locate research papers, admission forms, course outlines, annual reports, and other academic materials published on university websites. Here are the google Dorks that i Used:

```
site:au.edu.pk filetype:pdf
site:au.edu.pk filetype:doc OR filetype:docx
site:au.edu.pk filetype:xls OR filetype:xlsx
site:au.edu.pk filetype:ppt OR filetype:pptx
```

- Searching for SpreadSheet Documents (XLS / XLSX) on the Air University Website:

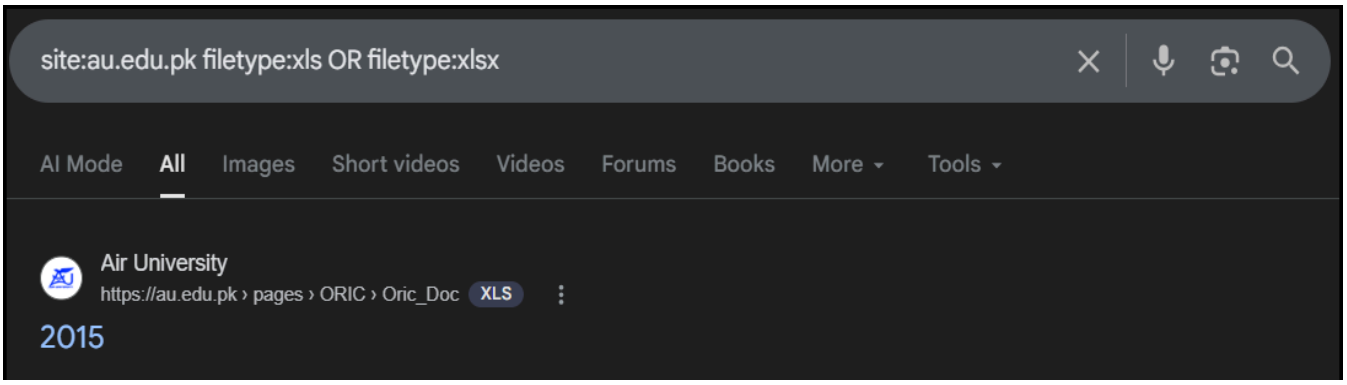


Figure 1: Searching for Files having XLS or XLSX Extension publicly available on AU site.

- Searching for PDF Documents (PDF) on the Air University Website:

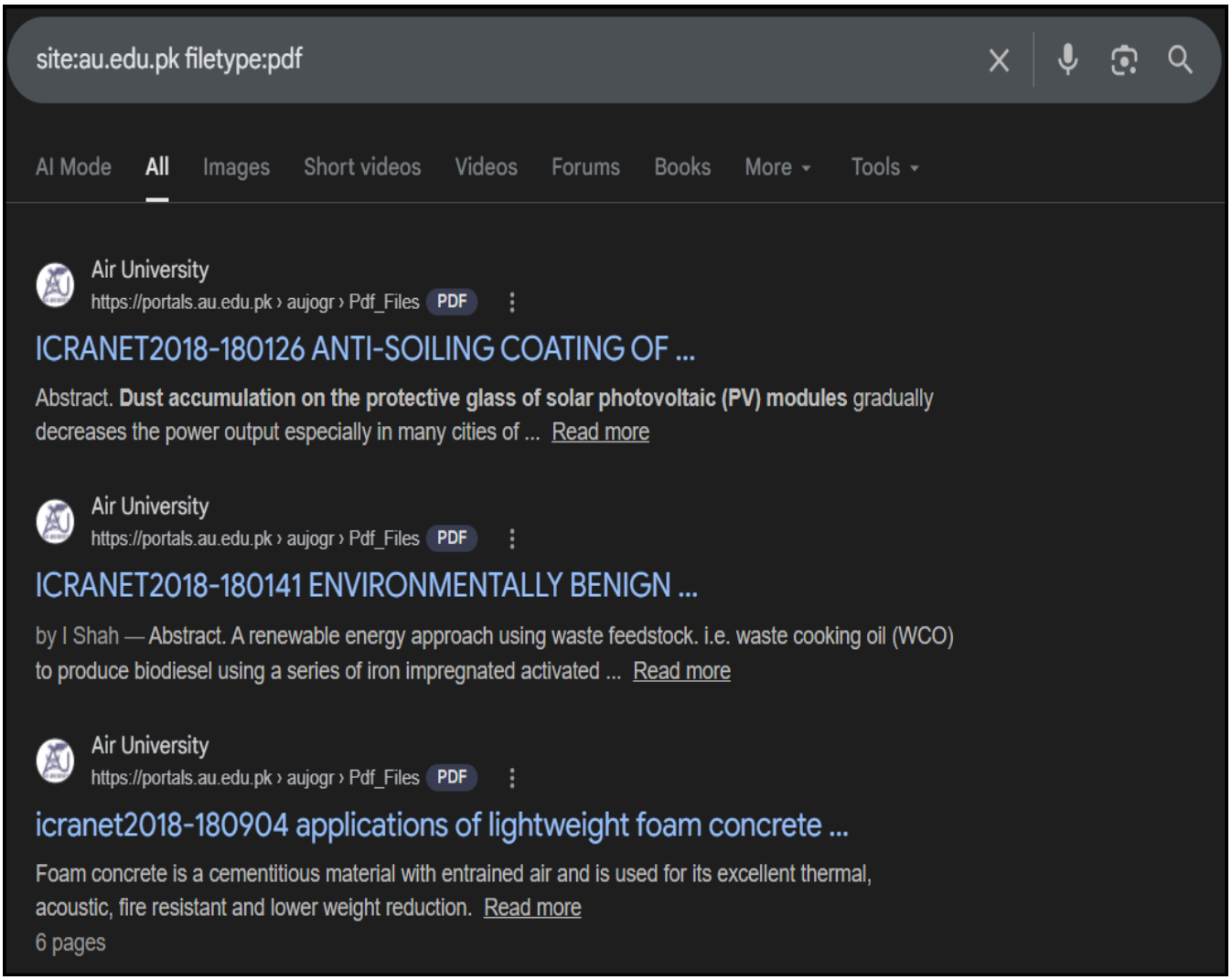


Figure 2: Searching for Files having the PDF file Extension publicly available on AU site.

- Searching for Word Documents (DOC / DOCX) on the Air University Website:

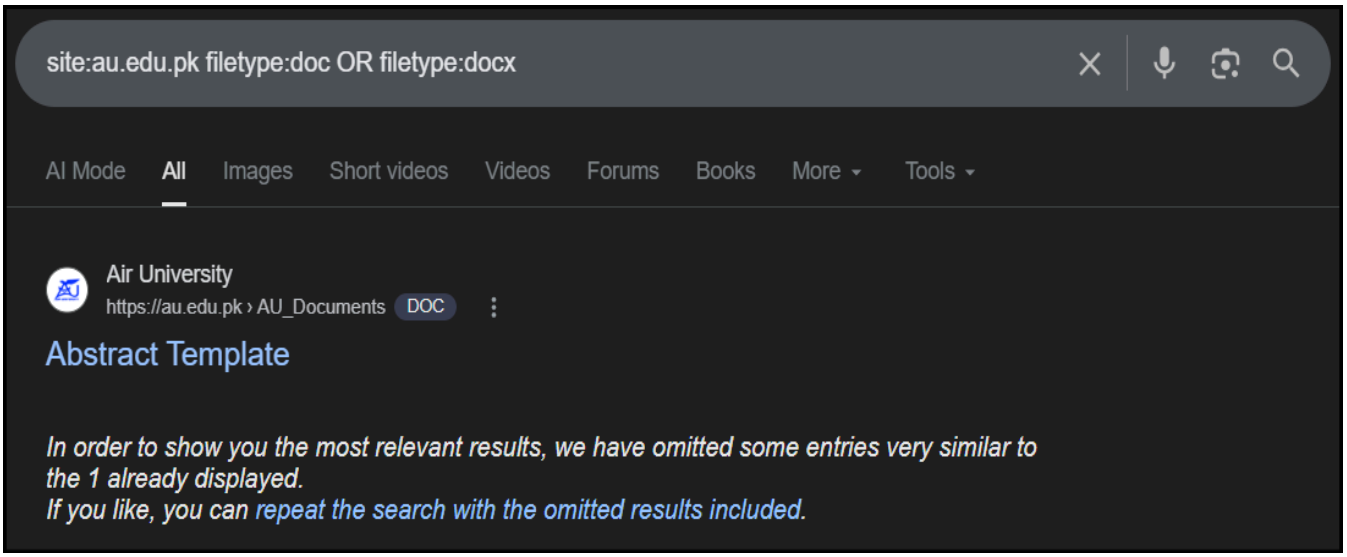


Figure 3: Searching for Files having DOC or DOCX Extension publicly available on AU site.

- Searching for Presentations (PPT / PPTX) on the Air University Website:

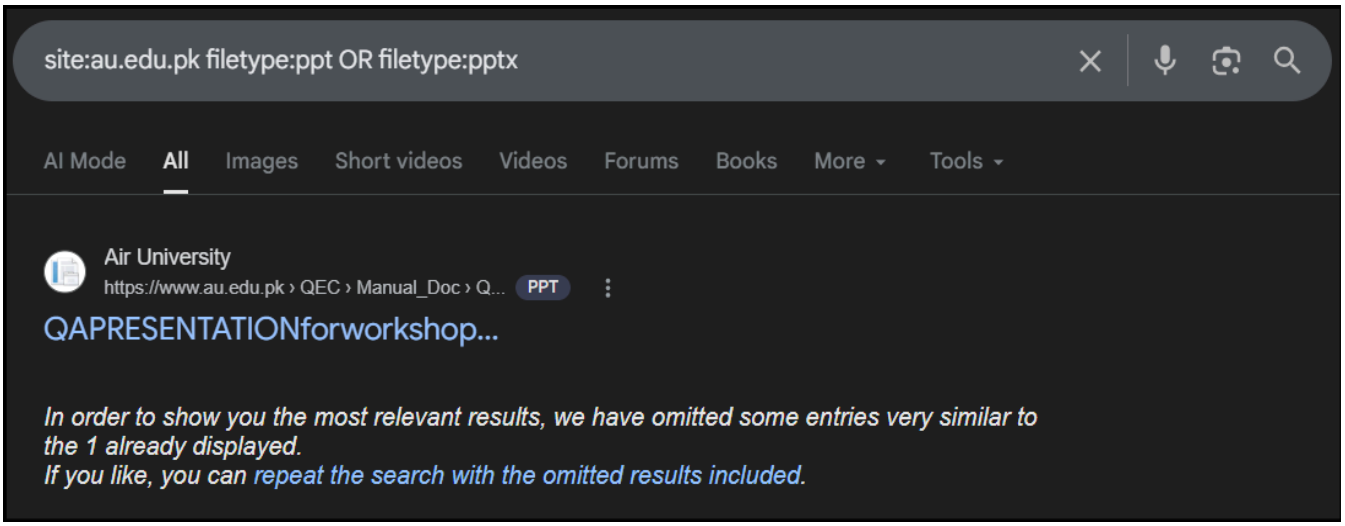


Figure 4: Searching for Files having PPT or PPTX Extension publicly available on AU site.

7.2.2. Finding Login/Signup portals

Google dorks like `site:au.edu.pk inurl:login OR inurl:portal OR inurl:admin` can be used to identify authentication pages on the target domain. These dorks help locate login panels, admin portals, student or staff sign-in pages, & other authentication interfaces that may be publicly accessible. Here are the Google Dorks that I used:

```
site:au.edu.pk inurl:login OR inurl:signin OR inurl:auth
site:au.edu.pk intitle:"login" OR intitle:"sign in"
site:au.edu.pk inurl:admin    (Found Nothing on this Dork)
site:au.edu.pk inurl:portal   (Found Nothing on this Dork)
```

- These pages can be targets for phishing or credential attacks against the target.

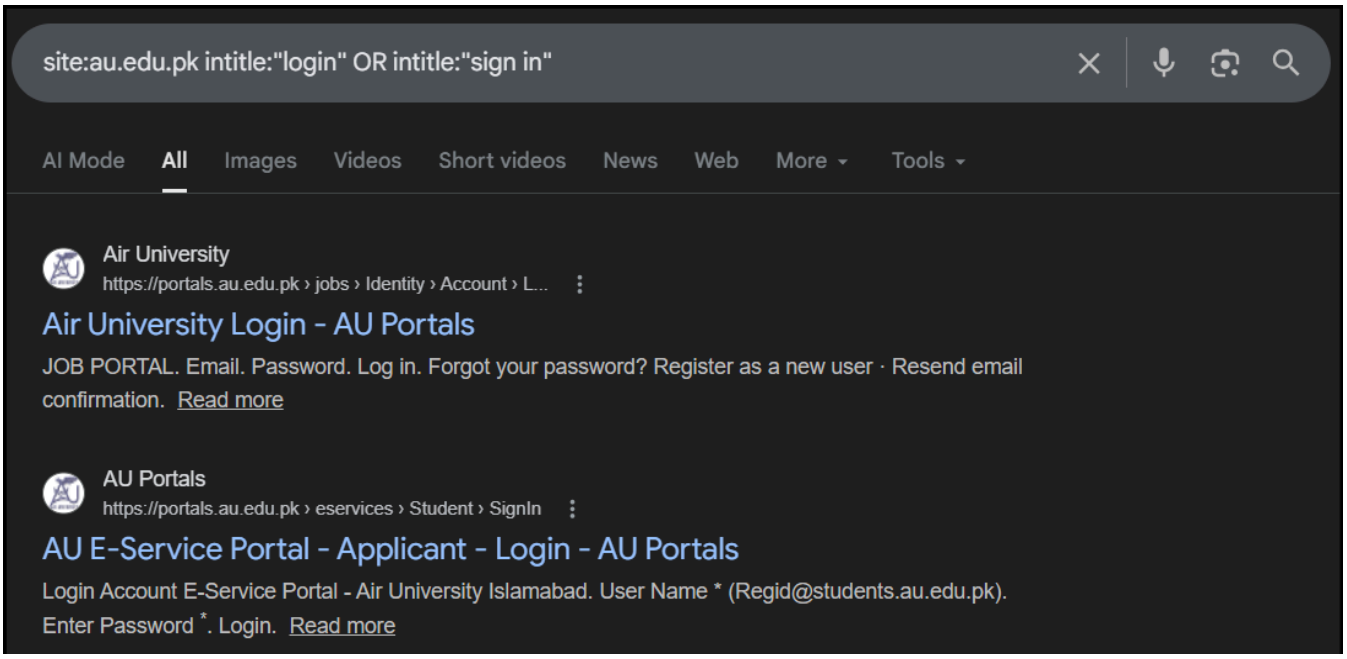


Figure 5-A: Searching for Login or Sign Up Portals on the AU website. (Finding A)

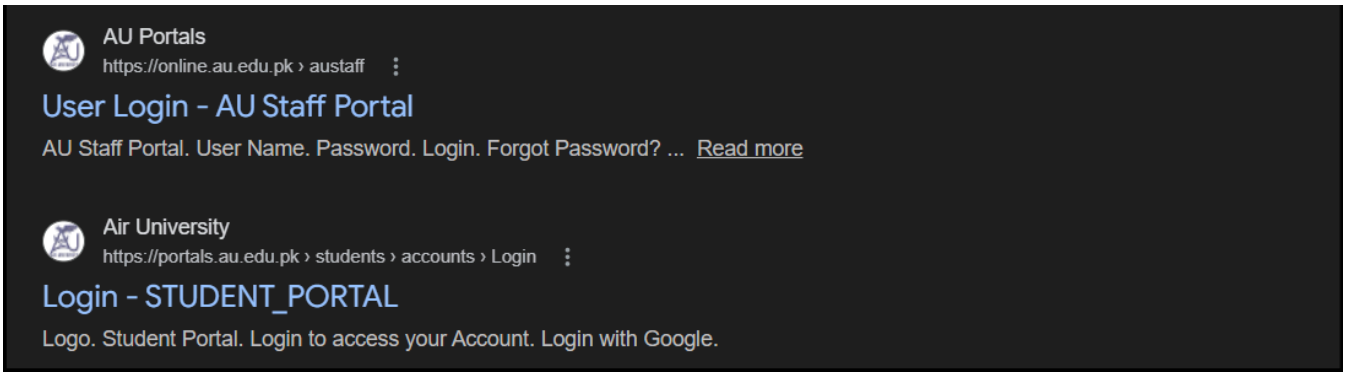


Figure 5-B: Searching for Login or Sign Up Portals on the AU website. (Finding B)

7.2.3. Identifying Email Formats

Google dorks like `site:au.edu.pk "@au.edu.pk"` and `site:au.edu.pk inurl:directory OR inurl:faculty` can be used to identify official email address patterns used by the organization. These dorks help locate faculty, staff, and departmental email addresses, which often reveal the standard email format (e.g., *first.last@au.edu.pk*). Directory and faculty profile pages commonly list names along with their official email addresses. Here are the Google Dorks that I used:

```
site:au.edu.pk "@au.edu.pk"
site:au.edu.pk "faculty" OR "staff" OR "directory"
```

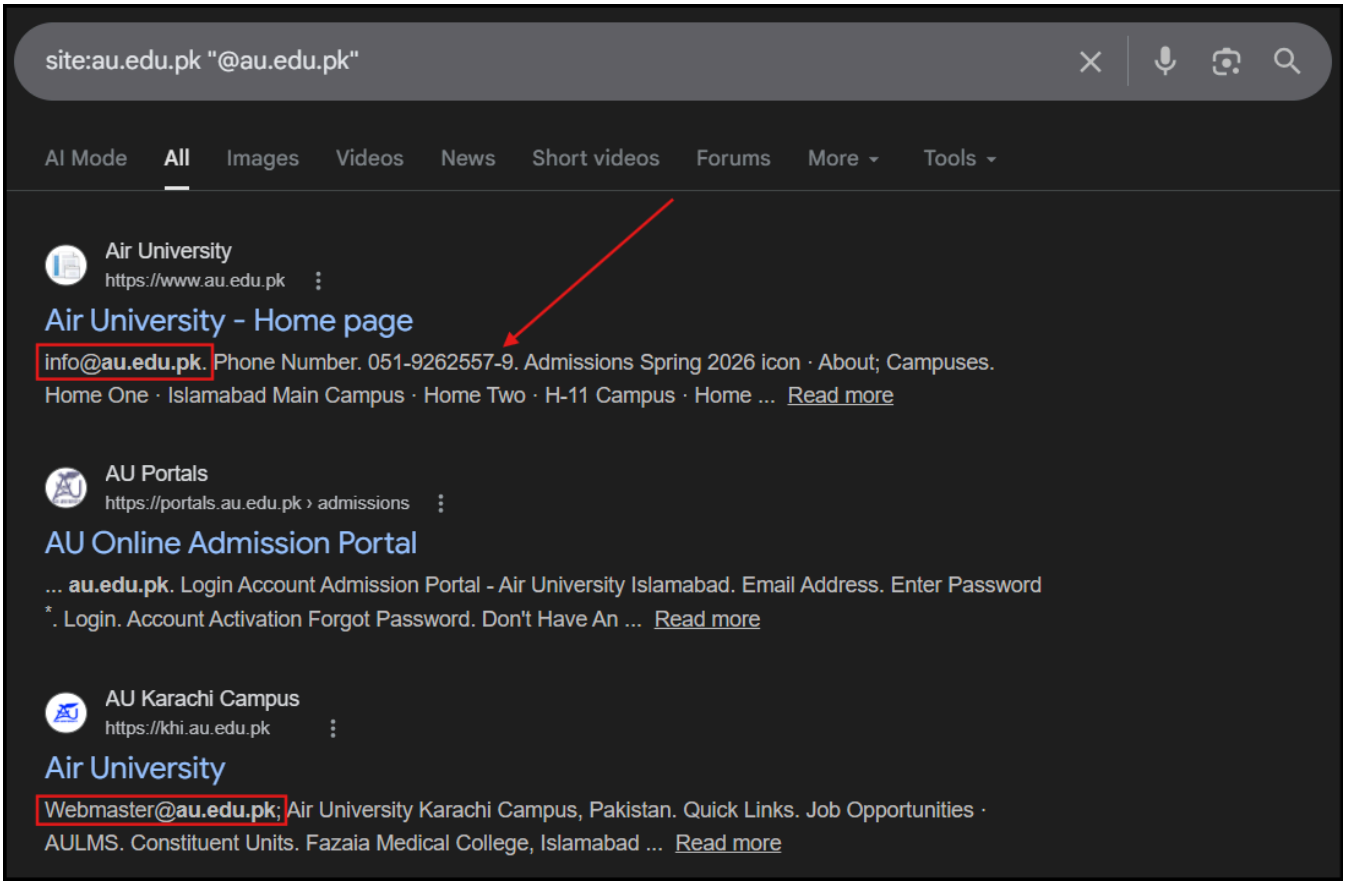


Figure 6-A: Searching for Email Address on the AU website. (Finding A)

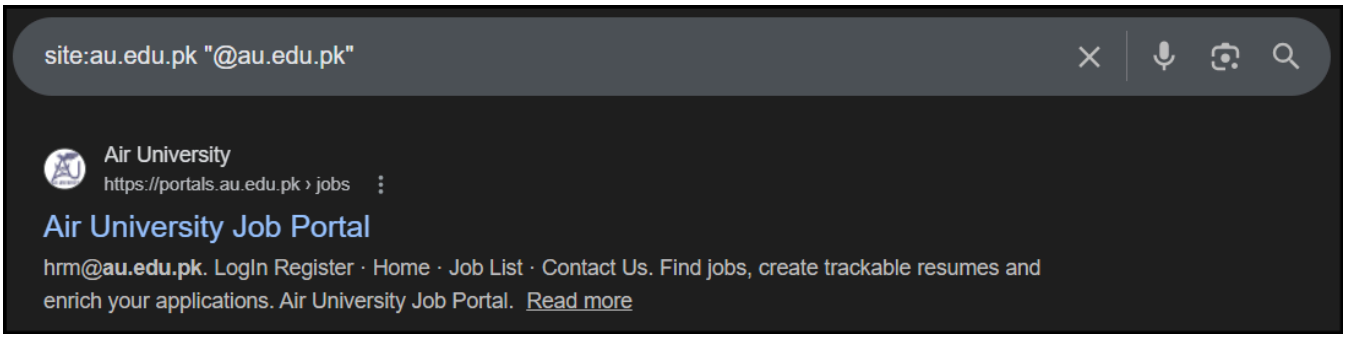


Figure 6-B: Searching for Email Address on the AU website. (Finding B)

7.2.4. Discovering Subdomains

Google dorks like `site:*.au.edu.pk` and `site:au.edu.pk -www` can be used to identify subdomains indexed by Google. These dorks help uncover different functional areas of the organization's infrastructure, such as library portals, admissions systems, learning management systems, and webmail services. By using these queries, I was only able to discover one extra subdomain `portals.au.edu.pk` and `journals.au.edu.pk` aside from the usual www subdomain. Here are the Google Dorks that I used:

```
site:*.au.edu.pk
site:au.edu.pk -www
```

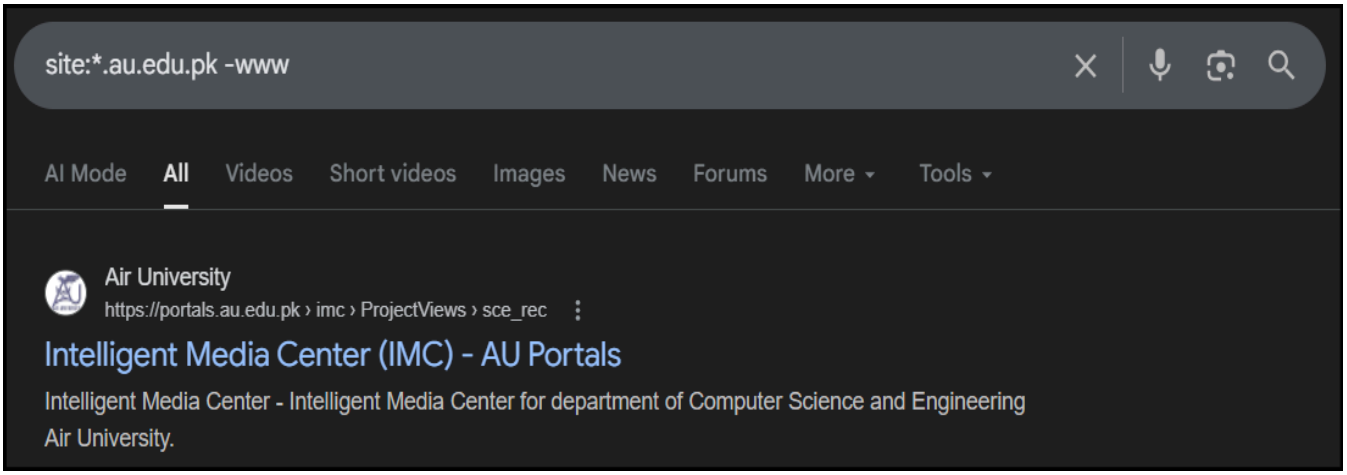


Figure 7: Searching for Subdomains of the AU website via Dorking.

7.2.5. Finding Exposed Directories

Google dorks like `site:au.edu.pk intitle:"index of"` and `site:au.edu.pk inurl:/backup/ OR inurl:/uploads/ OR inurl:/docs/ OR inurl:/files/` can be used to identify open directory listings that may unintentionally expose files. These dorks help locate publicly accessible folders that could contain backups, uploaded files, or internal documents. By using these queries, I discovered exposed directories such as `/ojs/registry`, `/ojs/pages`, and `/ojs/plugins`. Here are the Google Dorks that I used:

```
site:au.edu.pk intitle:"index of"
```

```
site:au.edu.pk intitle:"index of" /uploads
site:au.edu.pk intitle:"index of" /backup
site:au.edu.pk intitle:"index of" /private
site:au.edu.pk intitle:"index of" /public
```

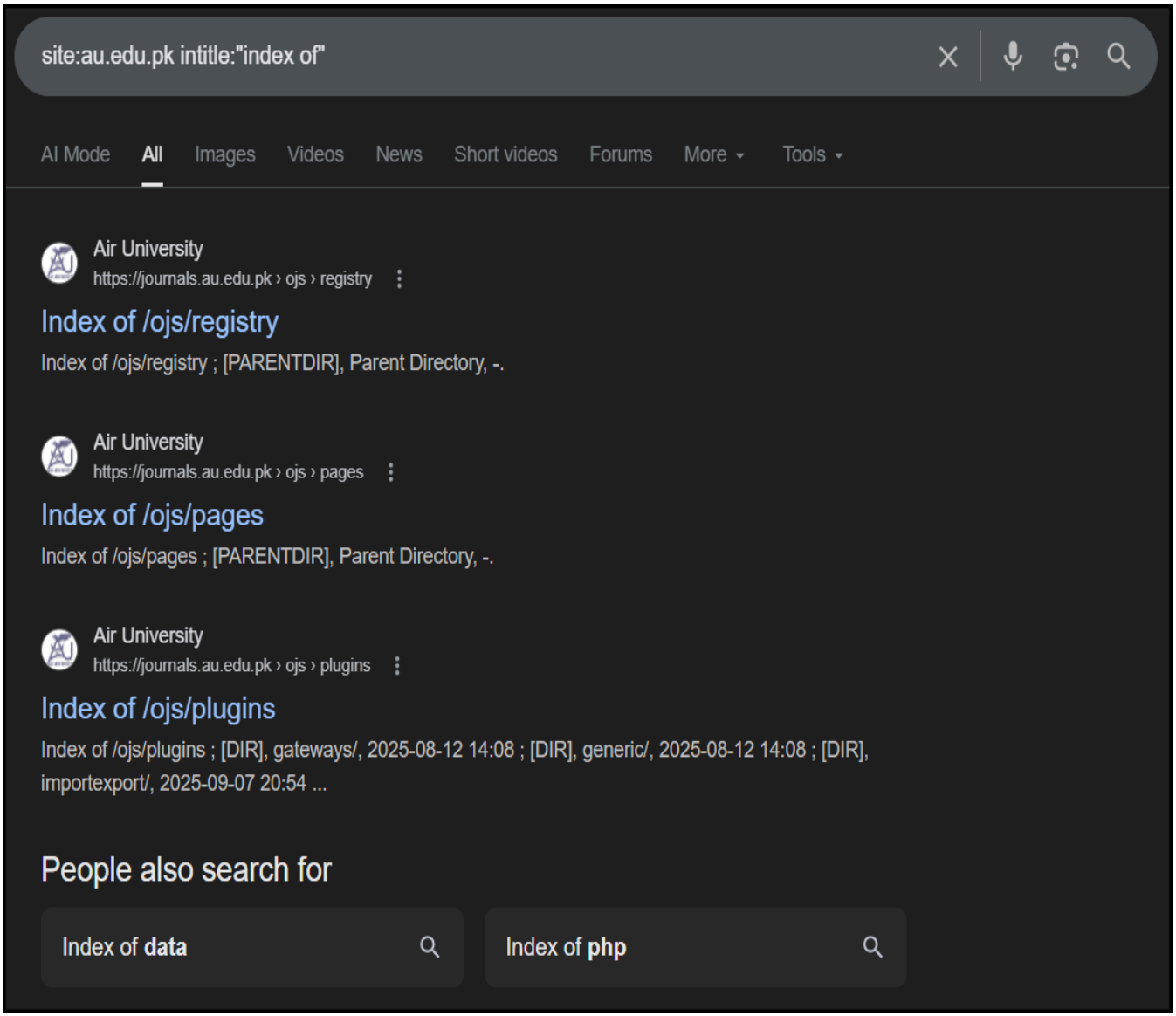


Figure 8: Searching for exposed sub-directories of the AU website via Dorking.

7.2.6. Publicly Available Sensitive Information

Publicly available sensitive information refers to confidential or internal data that is unintentionally exposed and indexed by search engines. This may include default credentials in documentation, internal-use-only files, database backups, or records containing personal information. To identify such exposures on the Air University website, I used the following google Dorks to look for Default Passwords/Credential:

```
site:au.edu.pk filetype:pdf intext:"password"
```

```
site:au.edu.pk filetype:doc intext:"username" OR "password"
site:au.edu.pk intext:"default password"
```

- I Used Them to check whether user manuals or documents contain example or default login credentials.
- I Discovered Some documents included login instructions and sample credential formats, but no active passwords were exposed.

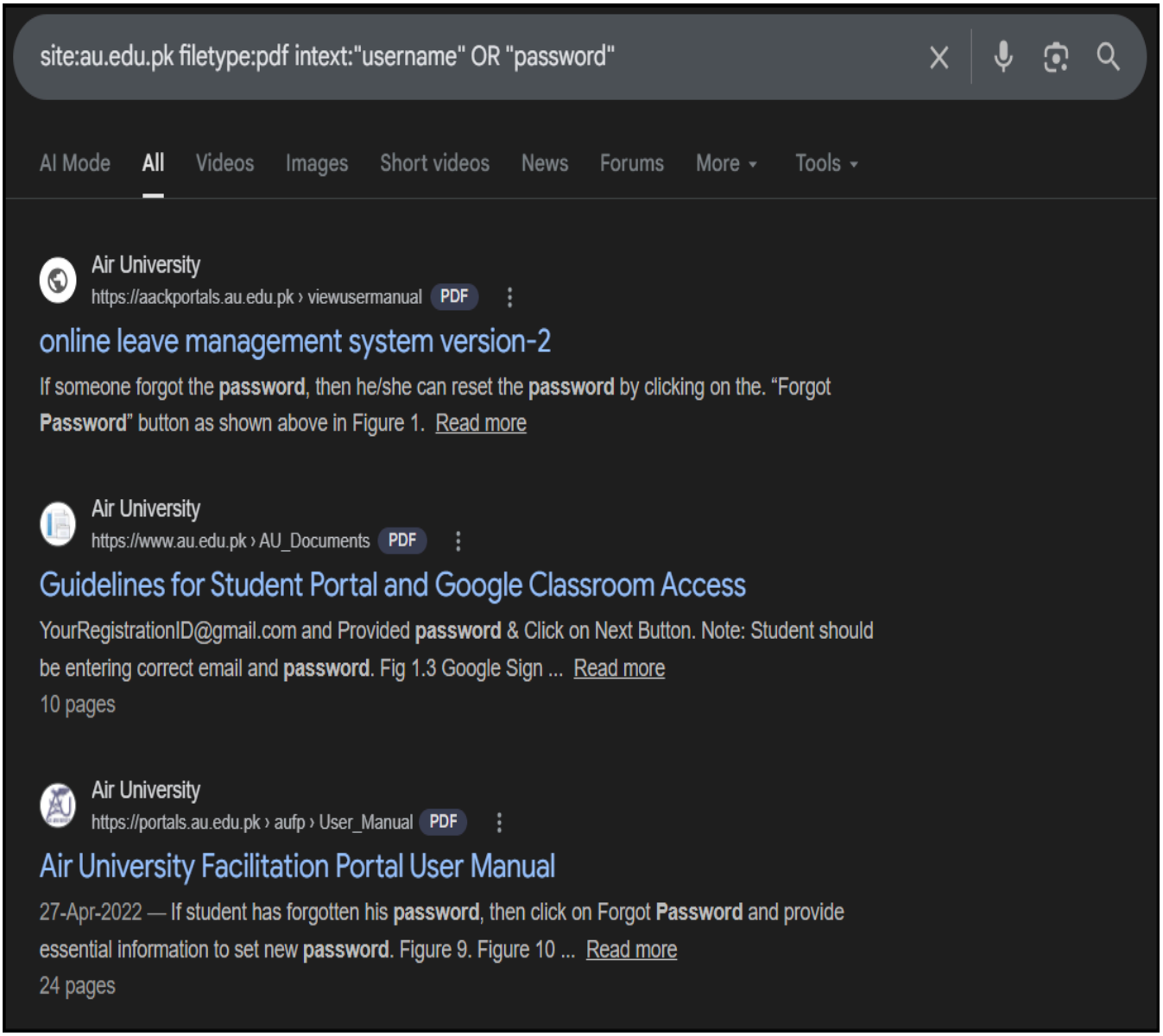


Figure 9: Searching for exposed sub-directories of the AU website via Dorking.

7.3. Task 3: Metadata Analysis (YouTube / Documents)

Metadata analysis means examining hidden information embedded within files or videos, such as author name, creation date, software used, tags, or upload details. This analysis can help uncover background information about the creator, organization, or system used, which may reveal additional insights beyond the visible content.

7.3.1. Youtube Video Metadata Analysis

I analyzed the video with a message from the Vice-Chancellor of Air University, Islamabad available on Youtube using the MW Metadata website and found the following details on the Channel and Video.

Publish Date	Channel ID	Video Title
Video Category	Video ID	Monetization Information
Channel Title	Channel search tag	Video Analytics
Banner Image URL	Thumbnail Image URLs	

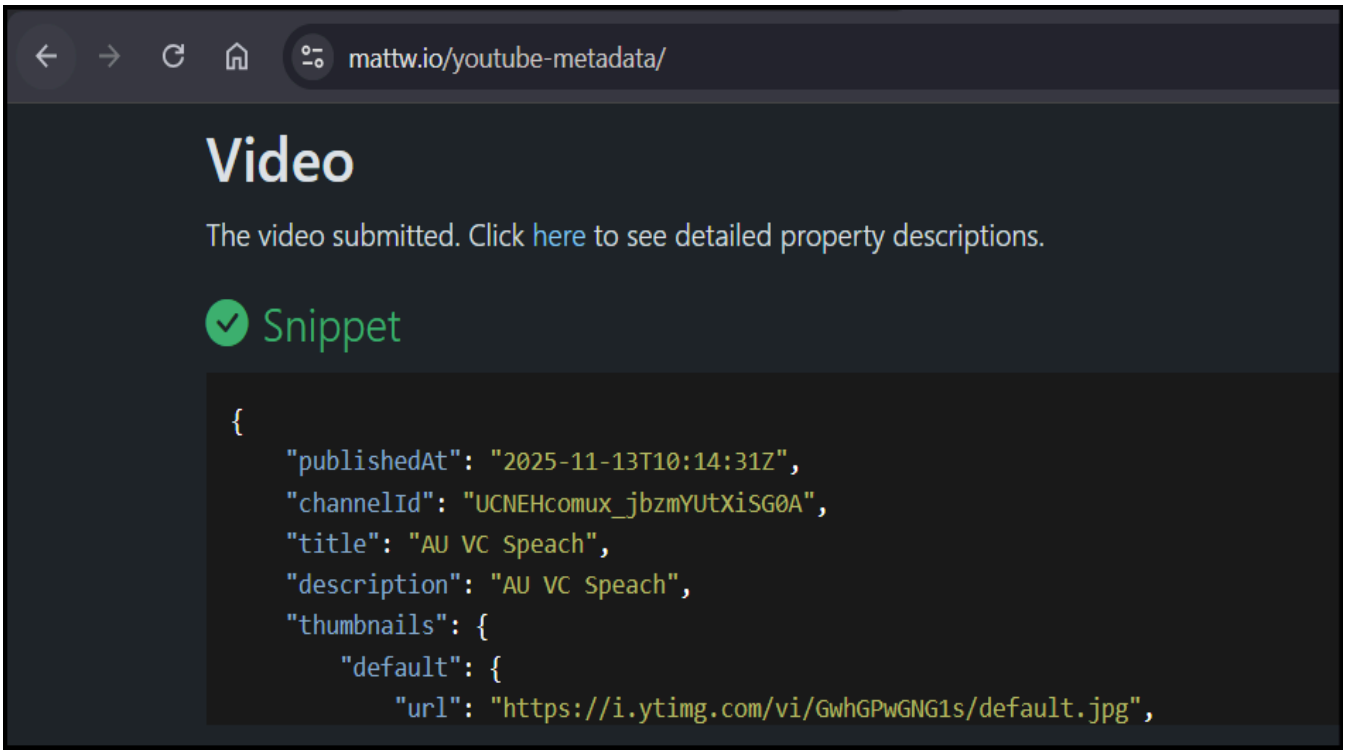


Figure 10: Video Metadata showing Video Publish Date, Channel ID, Title, Description, Thumbnail URL

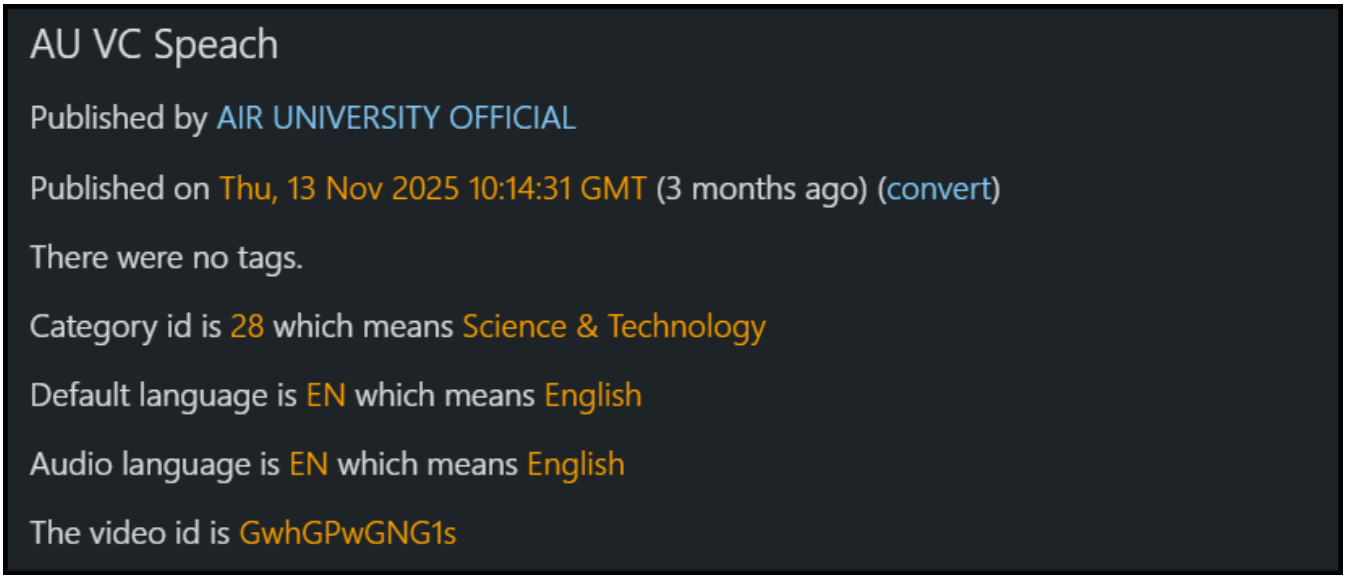


Figure 11: Video Metadata showing Channel Name, Publish Date, Category ID & Name, Video ID.

Localizations for...

- EN which is English

Content Details


```
{
    "duration": "PT3M45S",
    "dimension": "2d",
    "definition": "hd",
    "caption": "false",
    "licensedContent": false,
    "contentRating": {},
    "projection": "rectangular"
}
```


The video length was 3m 45s

Paid Promotion Details


```
{
    "hasPaidProductPlacement": false
}
```


This video does not contain paid promotion(s).

Figure 12: Video Metadata showing Video Duration, Dimension, License, Rating, and Caption settings.

The channel id is UCNEHcomux_jbzmYUtXiSG0A

Statistics


```
{
    "viewCount": "6774",
    "subscriberCount": "98",
    "hiddenSubscriberCount": false,
    "videoCount": "9"
}
```


This channel's subscriber count qualifies for benefit level graphite (1-1k). Click here to learn more.

Check out this channel on SocialBlade.

01 Inspect the metadata for all of this channel's videos

Branding Settings


```
{
    "channel": {
        "title": "AIR UNIVERSITY OFFICIAL"
    },
    "image": {
        "bannerExternalUrl": "https://yt3.googleusercontent.com/F1e_X0odaElnbAOJYjAeYQysF92nU2lNcAU3NeNGxDnt1W1ide5NEIcNVc083fmffbXOZ-e7luk"
    }
}
```


There were no keywords.

Figure 13: Video Metadata showing Video Statistics such as Views, Subscribers, total Videos, etc.

Figure 14: Video Metadata showing Channel Title, custom URL Tag, Channel Banner Image URL.

7.3.1.1. Document Metadata Analysis

I performed Document analysis on the Orientation Booklet (PDF Document) found through Google dorking on the Air University Website. I used the following website for metadata:

- Exif.tools
- Metadata2go

Page Count	21
Create Date	2021:09:09 16:47:13+05:00
Modify Date	2021:09:09 16:47:13+05:00
Producer	Corel PDF Engine Version 18.0.0.448
Author	AdministratorPC
Creator	CorelDRAW X8
Title	Untitled-1.cdr

Figure 15: File Metadata showing the total pages, creation and modify date, Author, Software, & Title

File Metadata

File Type: application/pdf
Error: 0
Upload Size: 7452066

exiftool:

Name	Value
ExifTool Version Number	12.25
File Name	phpoZldla
Directory	/tmp
File Size	7.1 MiB
File Modification Date/Time	2026:02:25 10:19:43+00:00
File Access Date/Time	2026:02:25 10:19:41+00:00
File Inode Change Date/Time	2026:02:25 10:19:43+00:00
File Permissions	-rw-------
File Type	PDF
File Type Extension	pdf
MIME Type	application/pdf
PDF Version	1.7
Linearized	No
Profile CMM Type	Adobe Systems Inc.

Figure 16: The Exiftool is used (V-12.25) that shows filename, size, MIME & File Type, Important Dates

Here are the answers to the intelligence i was required to extract:

- **Author names:**
  - PDF Document Author: AdministratorPC created the document using CoralDraw.
  - Youtube Channel Name: Air University Official (Tag: @airuniversityauofficial)
- **Software used:**
  - Base Software used: Google Chrome (Build Version: 146)
  - Websites for Youtube Metadata analysis: **MW Metadata**

- Websites for Document Metadata analysis: **Exif.tools** (`exiftool 12.25`)

- Internal naming conventions: Not Enough Information was found in this regard.
- Possible usernames
  - Lists of Email Address of Various People:
    - Contact Info for Individual on the Main Campus: (Link)
    - Contact info for Individuals on Kamra Campus: (Link)
  - Emails:
    - General Contact/Info Collection Email: info@students.au.edu.pk
    - Email for Human Resources Manager: hr@students.au.edu.pk
    - Email for Head Registrar: nafees@mail.au.edu.pk (Mr. Nafees Abbasi)
    - Email for Director QEC: dir.qec@mail.au.edu.pk

This kind of extracted metadata can help an attacker map your organization and plan **social engineering** or **phishing attacks**. Knowing specific emails (e.g., VC, HR, Registrar), software versions, and document authors allows them to craft highly convincing, targeted emails or exploit known vulnerabilities. It also helps in reconnaissance, which is the first stage of most cyberattacks.

7.4. Task 4: Shodan Intelligence Gathering

Shodan Intelligence Gathering is the process of using Shodan, a specialized search engine for internet-connected devices, to collect information about publicly exposed systems. It allows users to identify open ports, running services, software versions, IP addresses, and potential vulnerabilities. Attackers may use this information for reconnaissance before targeting a system, while security teams use it to detect and secure exposed assets.

7.4.1. Gathering Public IP details

- To get the Public IP Address of the Target (au.edu.pk) i used the ping method:

```
kali@LEOPARD-PC:~/Navttc-CEH$ ping -c 1 au.edu.pk
PING au.edu.pk (104.21.79.203) 56(84) bytes of data.
64 bytes from 104.21.79.203: icmp_seq=1 ttl=51 time=137 ms

--- au.edu.pk ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 137.237/137.237/137.237/0.000 ms
kali@LEOPARD-PC:~/Navttc-CEH$
```

Figure 17: Pinging the main site of Air University to get their Public IP Address (it may be a dummy IP)

- I used this method because Shodan had no data on Air University's Public IP directly.
- And as expected, when I searched for this IP on Shodan I got info from Cloudflare.

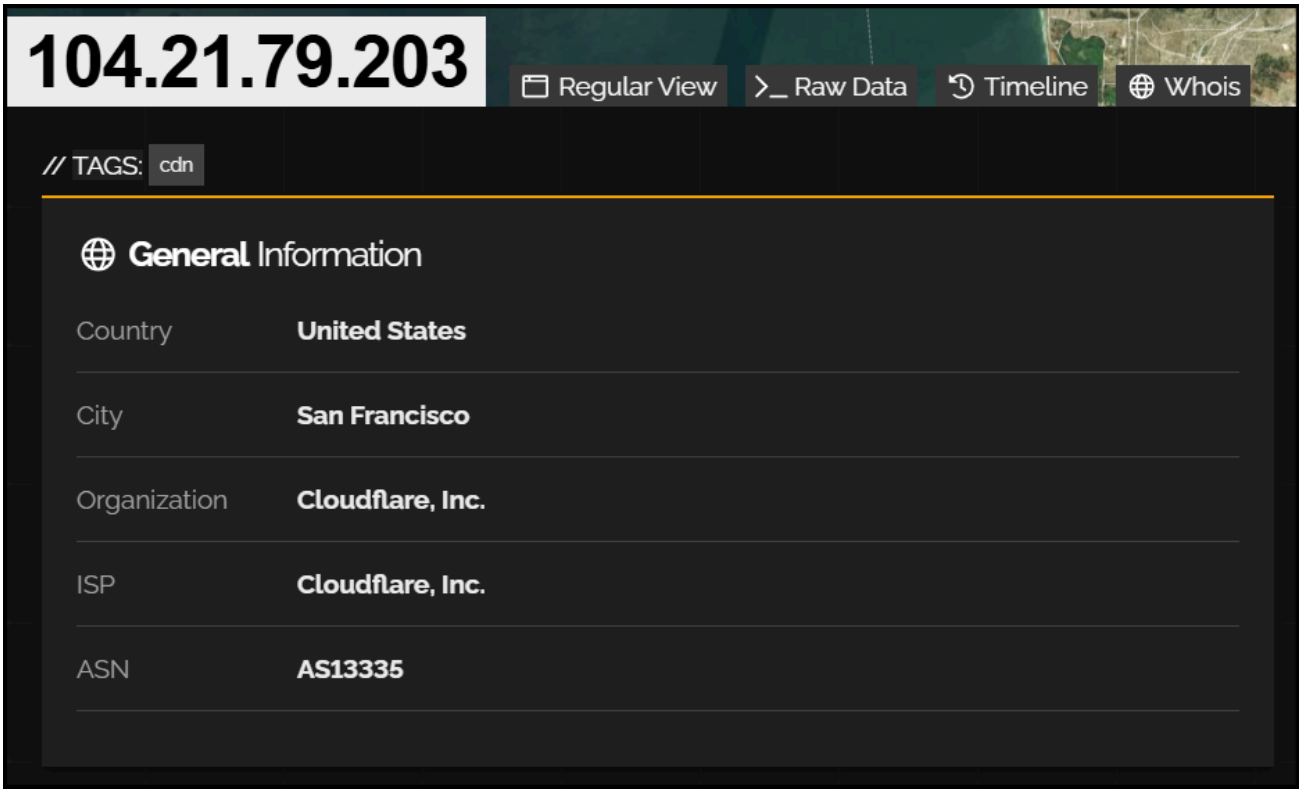
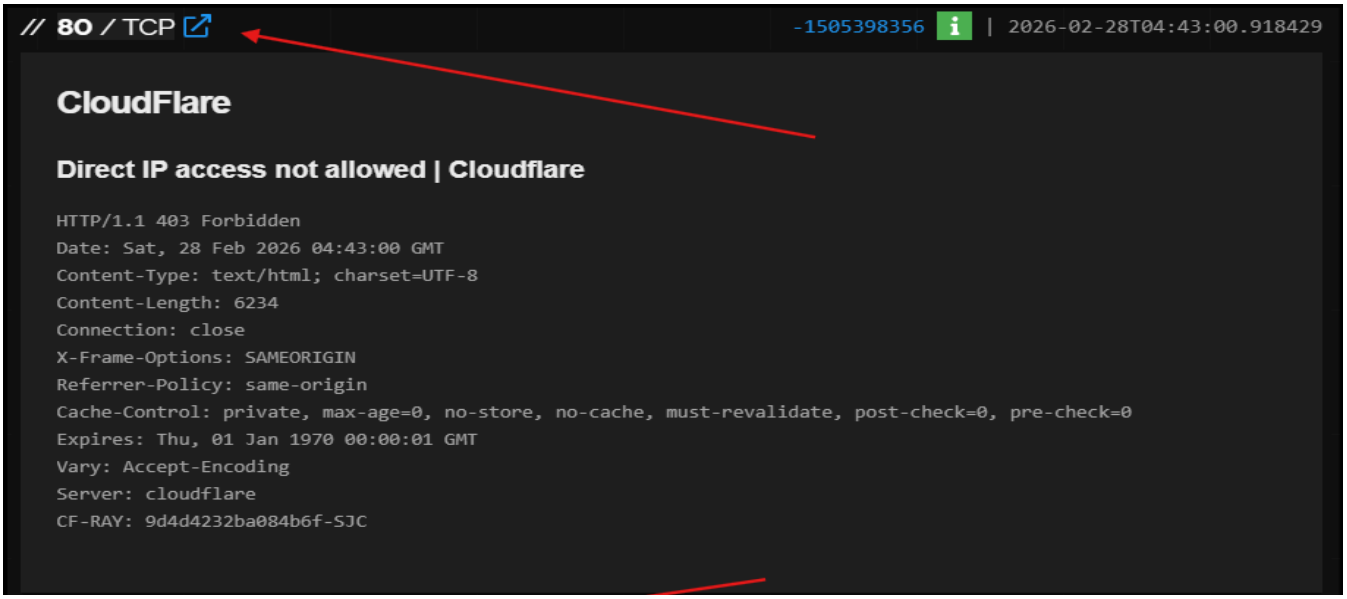


Figure 18: The public IP found appears to be a Cloudflare provided IP.

7.4.2. Searching for Open ports

- Looking at the Info found on previously found Public IP address, follow ports are open:

```
80, 443, 2052, 2082, 2083, 2086, 2087, 2095, 2096, 8080, 8443, 8880
```



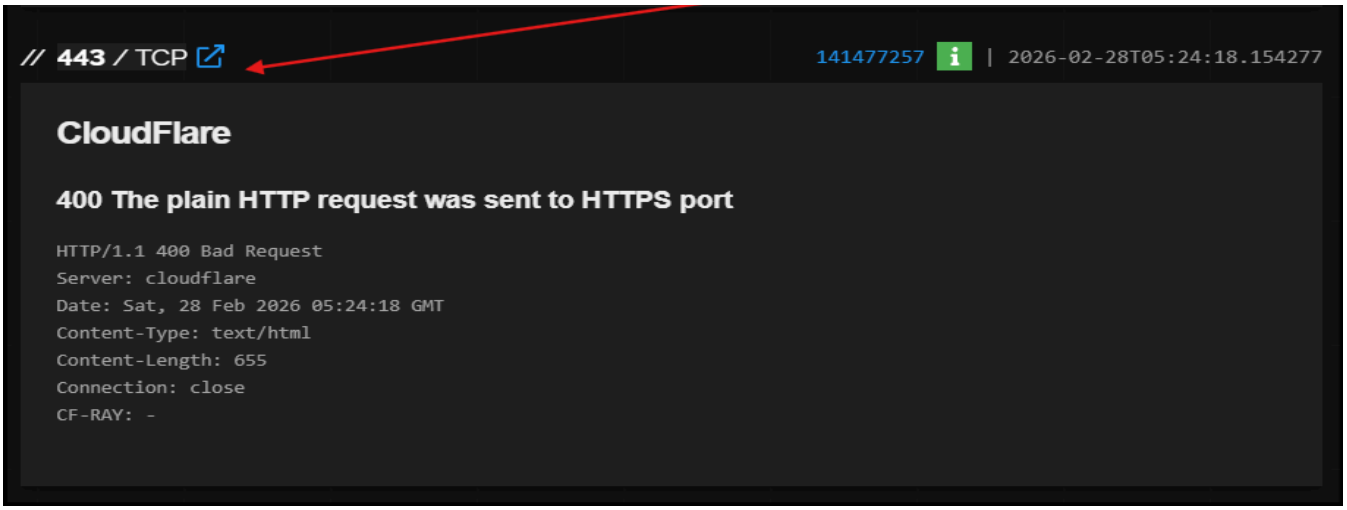


Figure 18: Looking for Information on the Open Ports found against the given IP Address.

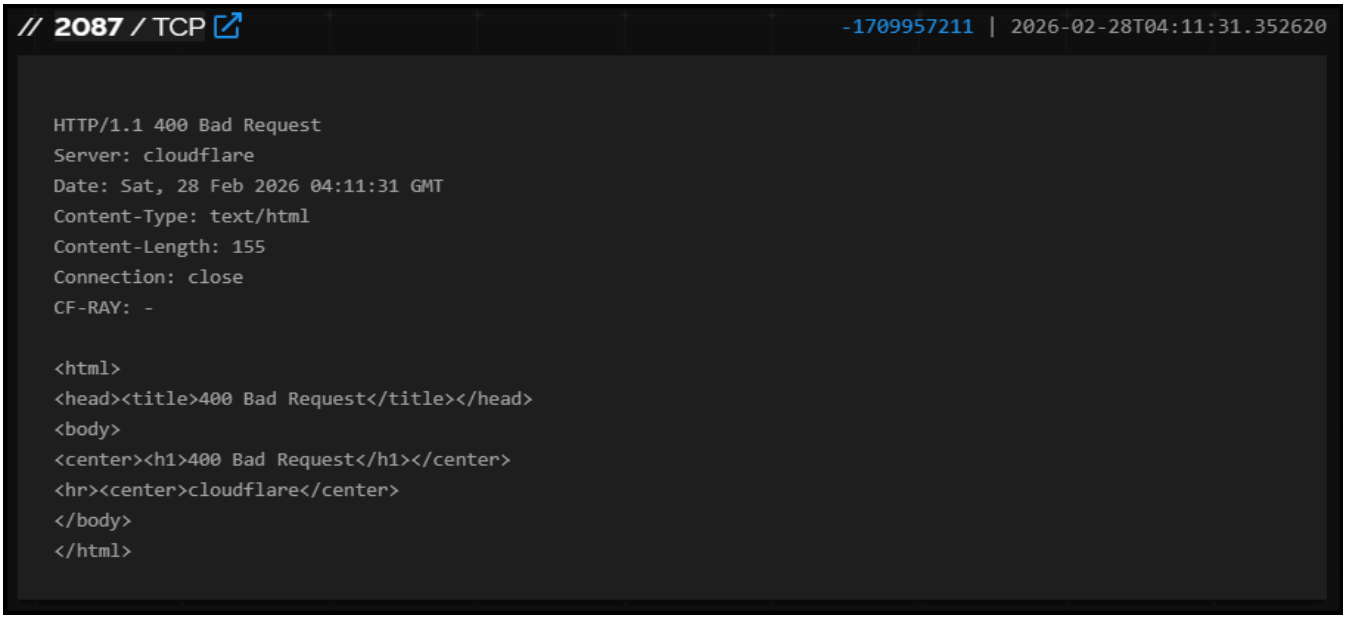


Figure 19: Port 2087 showing a Bad Request Message but when google it is used for Secure WHM

- Here is a brief summary of all Open Ports found against the found Public IP Address.

Port	Protocol	Service	Server	HTTP Status	Response Summary	Notes
80	TCP	HTTP	Cloudflare	403 Forbidden	Direct IP access not allowed	Protected by Cloudflare
443	TCP	HTTPS	Cloudflare	400 Bad Request	Plain HTTP sent to HTTPS port	SSL expected
2052	TCP	HTTP (Alt)	Cloudflare	403 Forbidden	Direct IP access not allowed	Cloudflare HTTP alt port
2082	TCP	cPanel	Cloudflare	403 Forbidden	Direct IP access not allowed	cPanel (non-SSL)
2083	TCP	cPanel (SSL)	Cloudflare	400 Bad Request	Plain HTTP sent to HTTPS port	Secure cPanel
2086	TCP	WHM	Cloudflare	403 Forbidden	Direct IP access not allowed	WHM (non-SSL)

2087	TCP	WHM (SSL)	Cloudflare	400 Bad Request	Bad Request	Secure WHM
2095	TCP	Webmail	Cloudflare	403 Forbidden	Direct IP access not allowed	Webmail (non-SSL)
2096	TCP	Webmail	Cloudflare	400 Bad Request	Plain HTTP sent to HTTPS port	Secure Webmail
8080	TCP	HTTP (Alt)	Cloudflare	403 Forbidden	Direct IP access not allowed	Alternate HTTP
8443	TCP	HTTPS (Alt)	Cloudflare	400 Bad Request	Plain HTTP sent to HTTPS port	Alternate HTTPS
8880	TCP	HTTP (Alt)	Cloudflare	403 Forbidden	Error code 1003	Cloudflare restricted

Figure 20: Table showing the Information gathered on the Open ports found against the Public IP.

7.4.3. Looking for Running Services

- Although this point is already covered in above Table, I will create another better table.
- The below table shows information on what the discovered services are usually about.

Port	Protocol	Service	Status	Description
80	TCP	HTTP	403 Forbidden	Standard web traffic protocol used to serve websites over the internet.
443	TCP	HTTPS	400 Bad Request	Secure web communication protocol using SSL/TLS encryption.
2052	TCP	HTTP (Alt)	403 Forbidden	Alternate HTTP port commonly used behind reverse proxies like Cloudflare.
2082	TCP	cPanel	403 Forbidden	Web-based hosting control panel for managing websites and servers (non-SSL).
2083	TCP	cPanel (SSL)	400 Bad Request	Secure version of cPanel for encrypted hosting management access.
2086	TCP	WHM	403 Forbidden	Web Host Manager interface for server administration (non-SSL).
2087	TCP	WHM (SSL)	400 Bad Request	Secure Web Host Manager interface for encrypted server administration.
2095	TCP	Webmail	403 Forbidden	Browser-based email access service (non-SSL).
2096	TCP	Webmail (SSL)	400 Bad Request	Secure browser-based email access using encryption.
8080	TCP	HTTP (Alt)	403 Forbidden	Alternative port for web traffic, often used for testing or proxy services.
8443	TCP	HTTPS (Alt)	400 Bad Request	Alternative secure web traffic port using SSL/TLS encryption.
8880	TCP	HTTP (Alt)	403 Forbidden	Alternate HTTP port sometimes used for proxy or CDN-related services.

Figure 21: Info gathered regarding the commonly used services or service active on the open ports

7.4.4. Website Technologies

- Shodan was only able to identify `Cloudflare` (CDN) as the only technology used.

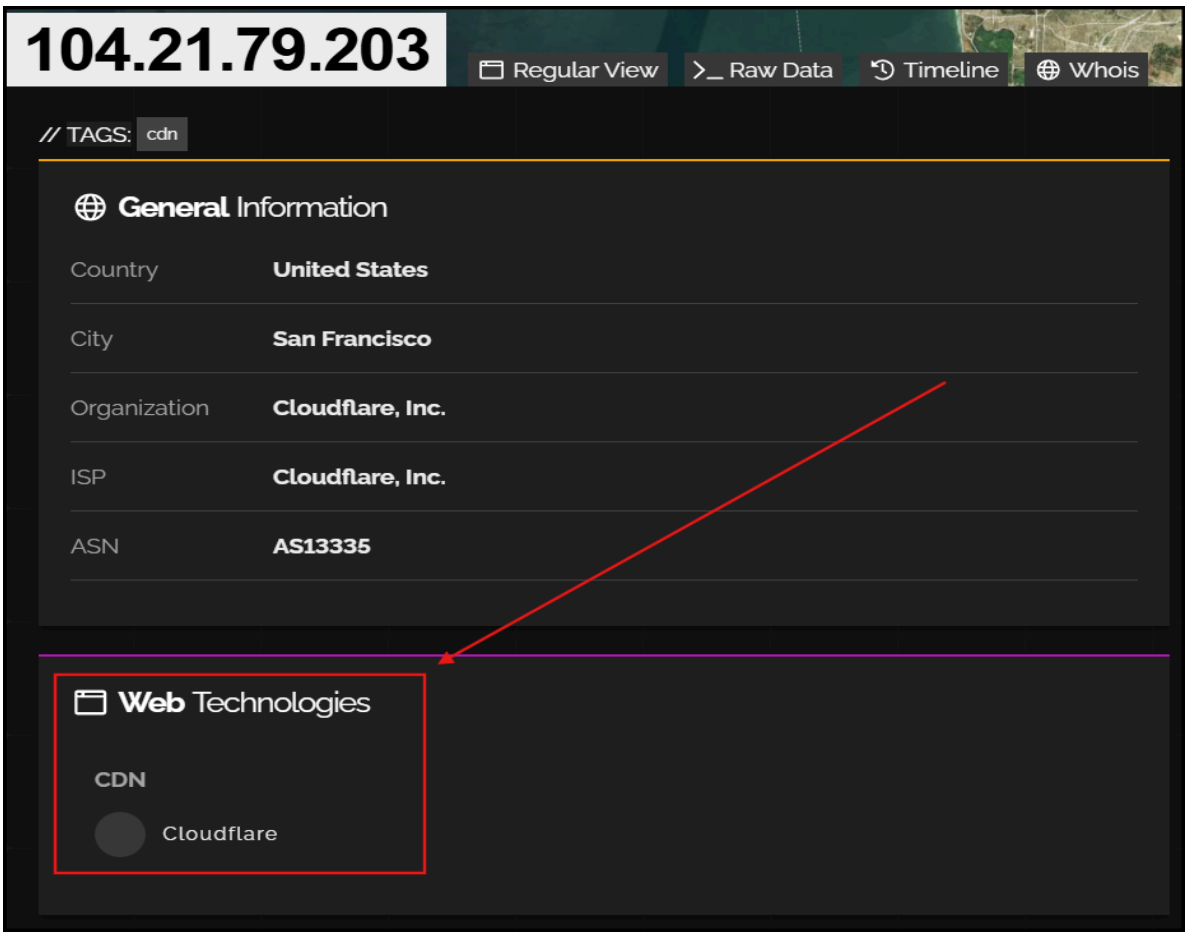


Figure 22: Web Technologies information gathered by the Shodan Tool against the Target IP Address.

- But by using a tool/extension called Wappalyzer on my Laptop, I was able to find more.

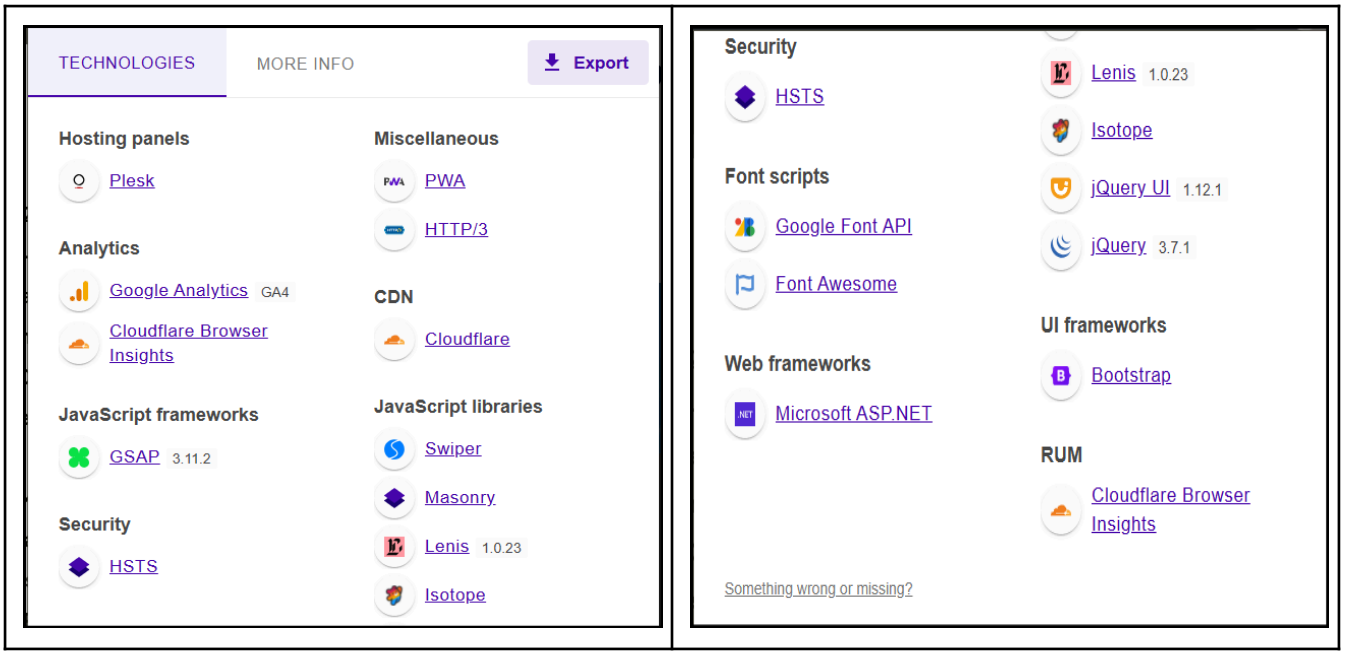


Figure 23 & 24: Web Technologies info gathered by Wappalyzer against the Target IP Address.

7.4.5. Possible exposed systems

- It is extremely hard to determine the exposed systems with the data gathered above.
- This is mainly due to the usage of an Air-Gapped or DMZ based network.
- Hence, I can't properly answer this question from an outsider's perspective.

7.5. Task 5: Netcraft Tools Analysis

- I ran the Netcraft tool's Site report generation against the AU website & got this info.

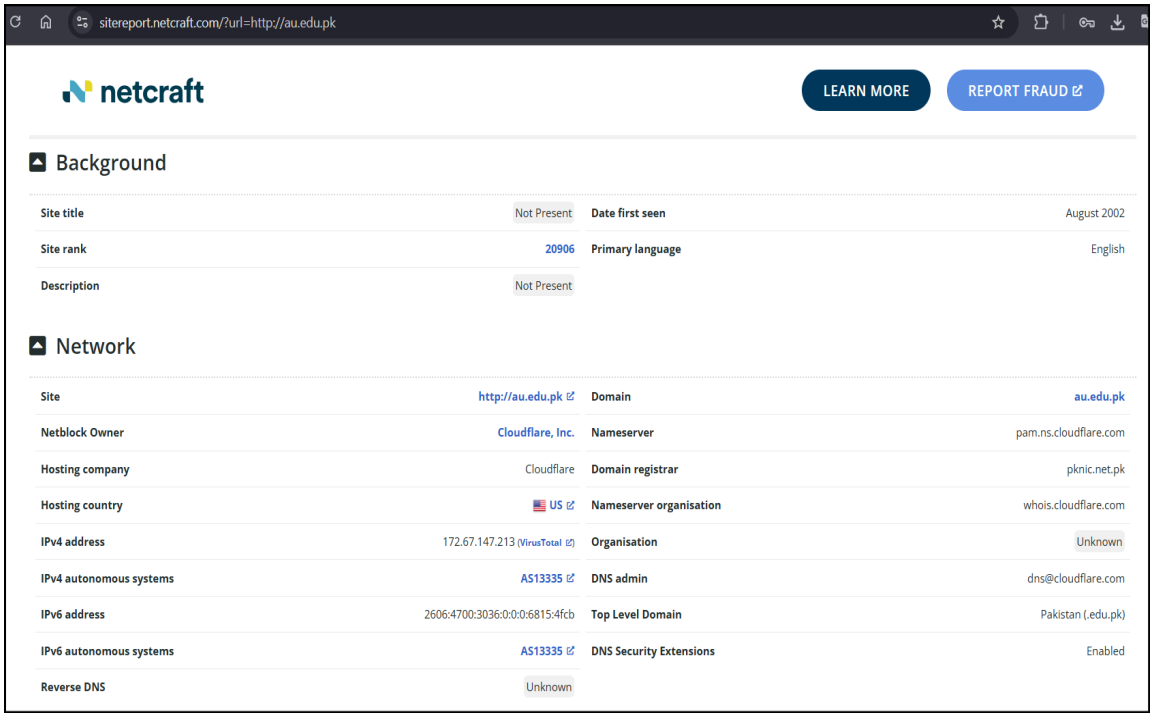


Figure 25: Background and Network Related information found against the AU Website.

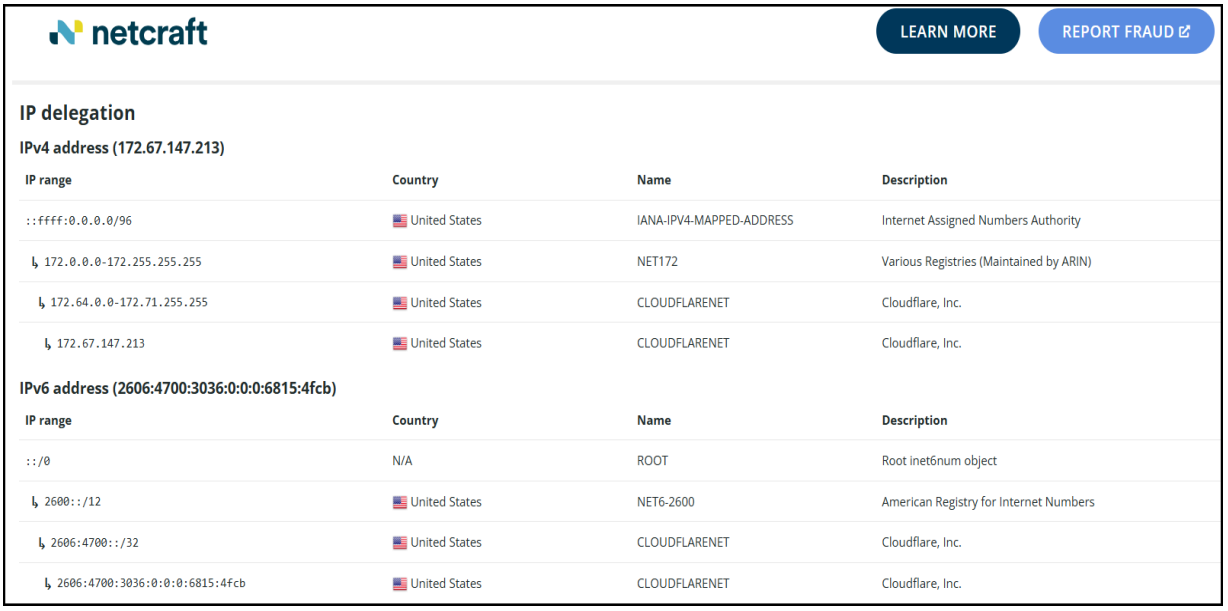


Figure 26: Information provided related to the IP Address delegation to the site by Cloudflare.

SSL/TLS

This is not a HTTPS site. If you're looking for SSL/TLS information try the **HTTPS site report**.

Sender Policy Framework

A host's Sender Policy Framework (SPF) describes who can send mail on its behalf. This is done by publishing an SPF record c
qualifier followed by a specification of which domains to apply this qualifier to. For more information please see **open-spf.org**.

Qualifier	Mechanism	Argument
+ (Pass)	ip4	111.68.96.98
+ (Pass)	include	spf.protection.outlook.com
~ (SoftFail)	all	

DMARC

DMARC (Domain-based Message Authentication, Reporting and Conformance) is a mechanism for domain owners to indicate
should be authenticated. It builds on SPF and DKIM, providing a method to set policy and to give reporting of failures. For more inf

This host does not have a DMARC record.

Figure 27: Information related to SSL/TLS (Not found), SPF (Pass), and DMARC (No Records).

Here is information regarding what was requested of me to submit in this task.

- **Hosting provider:** The site is hosted by Cloudflare, Inc. (AS13335) in United States.
- **Web technologies:**
  - Uses Cloudflare CDN and SSL/TLS (Secure Sockets/Transport Layer Security).
  - This indicates content delivery (CDN) and encrypted communication support.
- **Server type:**
  - The server is behind *Cloudflare's reverse proxy/CDN.*
  - Cloudflare usually allows for masking origin web servers.
- **Operating system guess:**
  - The actual OS cannot be determined due to Cloudflare protection
  - But likely a Linux-based web server (common for such setups).
- **Security headers:**
  - DNSSEC is enabled but *no DMARC record* is present
  - Sender Policy Framework (SPF) is configured

- Cloudflare typically adds security-related HTTP protections.

7.6. Task 6: FTP Intelligence (NAPALM FTP Indexer)

- I tried a lot of different inputs to gather data on my Target but got no luck.
- The main reason for this could be that Air University does not have FTP servers.
- And another reason could be that the index for AU's FTP servers are not present here.
- The second reason could only be true if the FTP servers are private or non-existent.

Figure 28, 29, 30, & 31: No Information (FTP indexes found against AU Website, Domains, or IPs)

- The only time I found something, it was for a different institute having the same name.

Figure 32: Data about the AirUniversityPress which is not related to my Target.

- There were NO exposed FTP directories or files found during the scan.
- Misconfigured FTP servers can expose sensitive files, backups, credentials.
- Or allow anonymous access, leading to data leakage or unauthorized modification.
- Even when nothing is found, FTP enumeration is an important reconnaissance step.
- Because it verifies whether legacy or misconfigured FT services are publicly accessible.

7.7. Task 7: Pentest Tool Recon Data

7.7.1. Performing a Subdomain Finder Scan

- First of all, I logged into the Account I had created during the Lab to get better results.

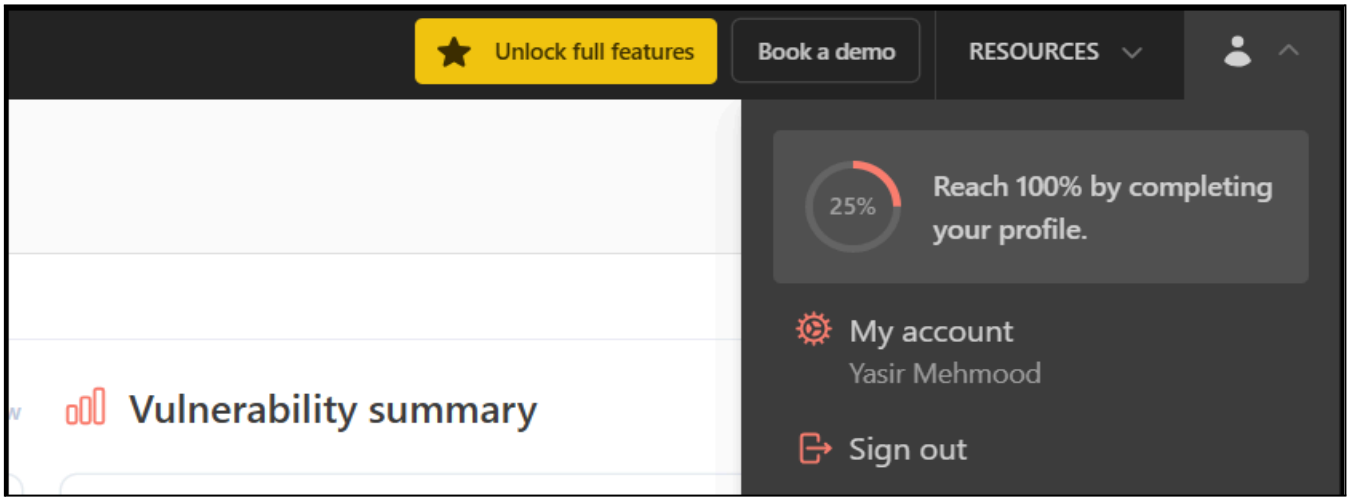


Figure 33: Logging into my Pentest-Tools account to get better results because it usually requires it.

- First i started out by performing subdomain finder scan against my target to discover:
  - Domains & Subdomains
  - Possibly IP Address
  - DNS Information

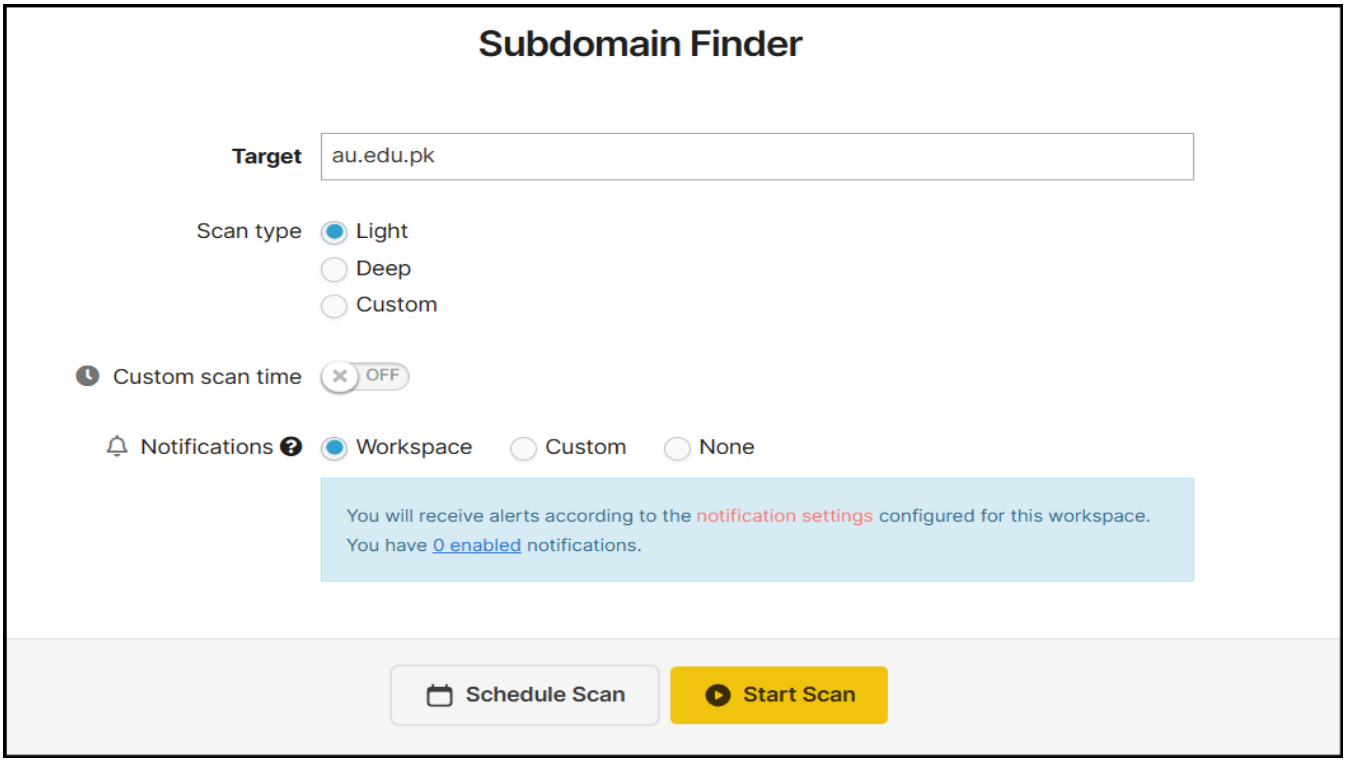


Figure 34: Selecting the Subdomain Finder scan option and setting up the Scan Settings.

- After the completion, the pentest-tools side found 51 Subdomains in under 41 seconds.

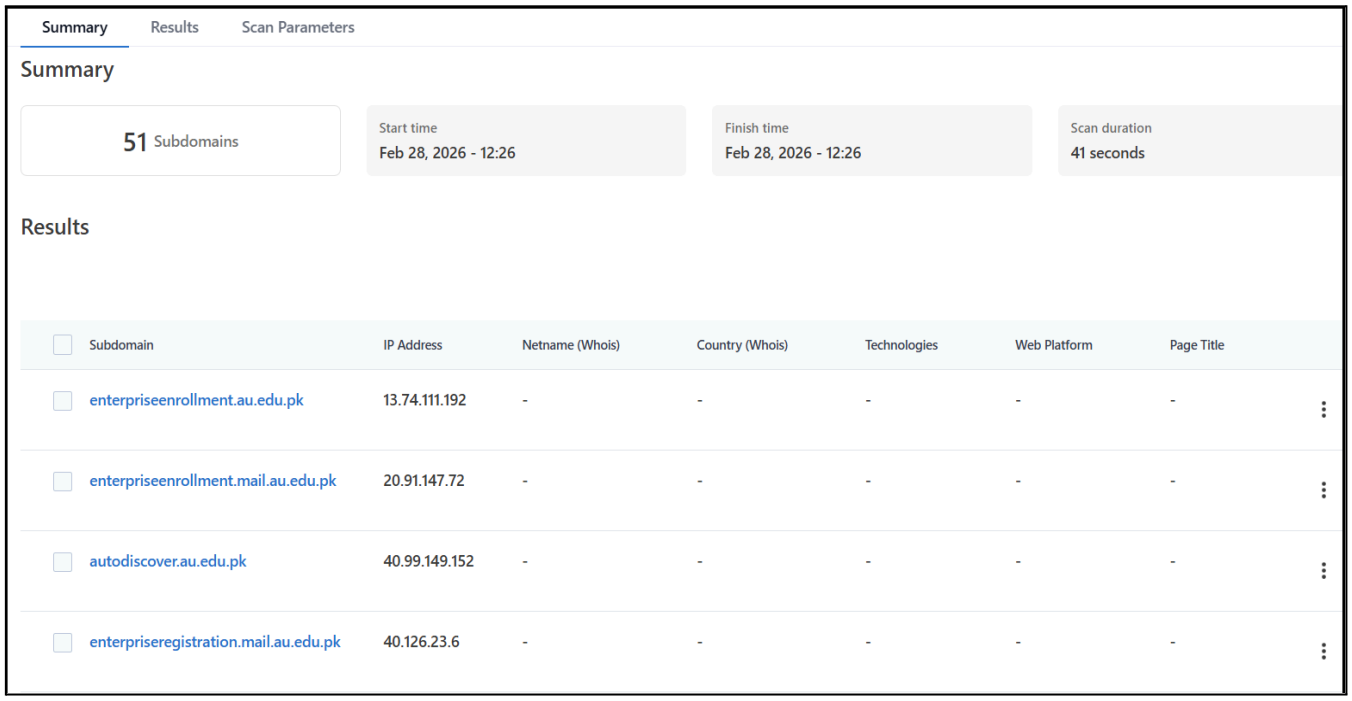


Figure 35: Pentest tools was able to find 51 Subdomains in under 41 seconds with 39 active ones.

- Of the resulting data, Here is the facts extract from the results:
  - 39 Subdomains were active and an IP Address Associated.
  - 12 Subdomains were inactive and no IP associated with them.
  - A total of 8 Unique IPv4 Addresses were discovered in this scan.

List of Discovered IP Address in the Pentest Tools Scan			
172.67.147.213	104.21.79.203	52.97.165.152	40.126.26.17
40.126.23.6	40.99.149.152	20.91.147.72	13.74.111.192

- Most of the Subdomains discovered were access restricted via Cloudflare WAF.

Subdomain	IP address
enterpriseenrollment.au.edu.pk	13.74.111.192
enterpriseenrollment.mail.au.edu.pk	20.91.147.72
autodiscover.au.edu.pk	40.99.149.152
enterpriseregistration.mail.au.edu.pk	40.126.23.6
enterpriseregistration.au.edu.pk	40.126.26.17
autodiscover.mail.au.edu.pk	52.97.165.152
online.au.edu.pk	104.21.79.203
aackportals.au.edu.pk	104.21.79.203
khiportals.au.edu.pk	104.21.79.203

Subdomain	IP address
library.au.edu.pk	104.21.79.203
khi.au.edu.pk	104.21.79.203
mail4.au.edu.pk	104.21.79.203
sip.um.au.edu.pk	104.21.79.203
urdu.au.edu.pk	104.21.79.203
www.portals.au.edu.pk	104.21.79.203
um.au.edu.pk	104.21.79.203
access.um.au.edu.pk	104.21.79.203
kc.au.edu.pk	104.21.79.203
msoid.au.edu.pk	104.21.79.203
av.um.au.edu.pk	104.21.79.203
webconf.um.au.edu.pk	104.21.79.203
kportals.au.edu.pk	172.67.147.213
www.au.edu.pk	172.67.147.213
scc.au.edu.pk	172.67.147.213
results.au.edu.pk	172.67.147.213

Figure 36: List of all the Active Subdomains discovered against the Target.

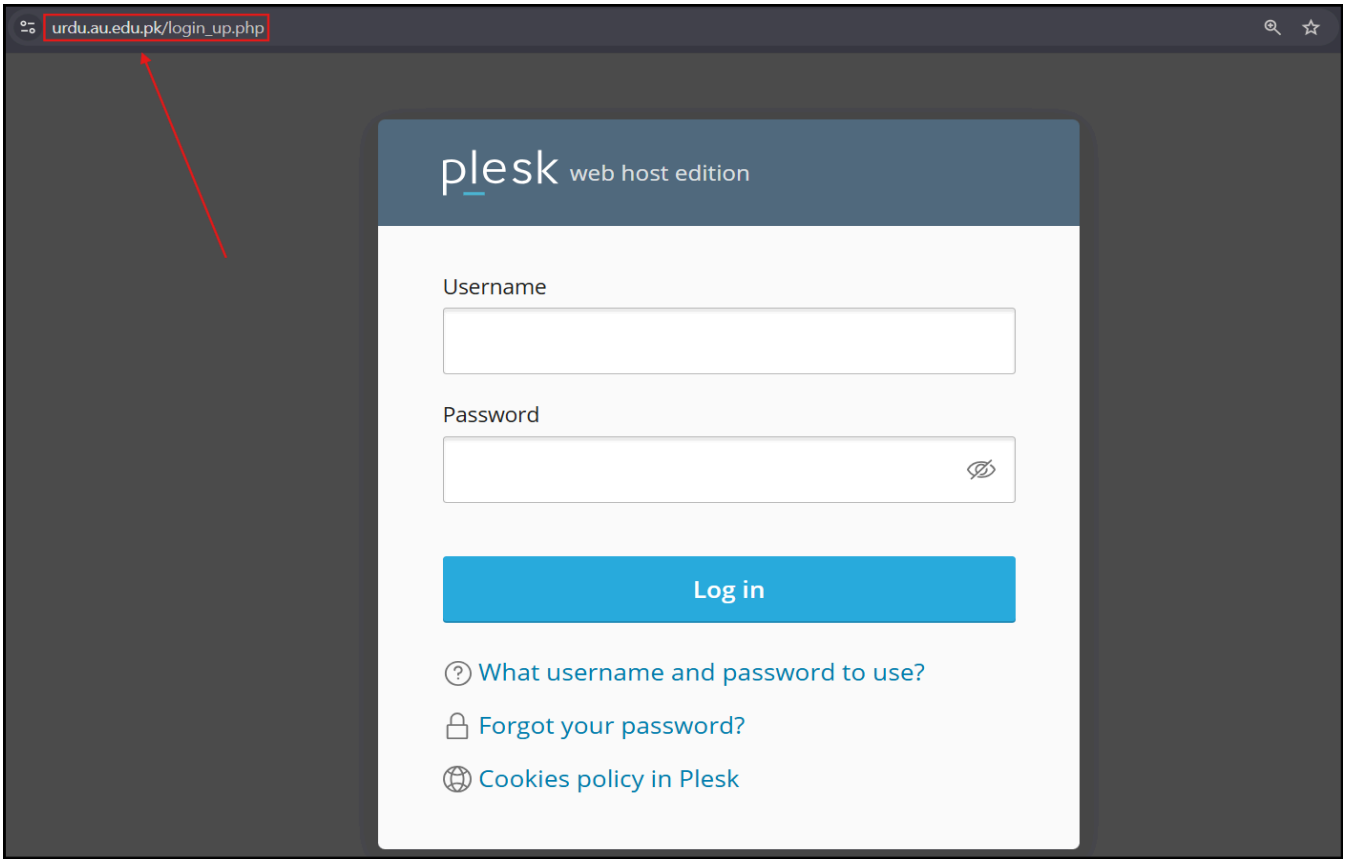


Figure 37: Discovered a Plesk Obsidian 18.0.56 installed on one of the subdomains.

- In the above subdomain list table, only the active subdomains having IPs are shown.

7.7.2. Performing a Website Recon Scan

- After analyzing the results in the first scan, I started another “Website Recon” scan.
- The first scan was able to provide the DNS Information, Subdomains, and IPs.
- Now the second subdomain was to discover the Technology stack and Email pattern.

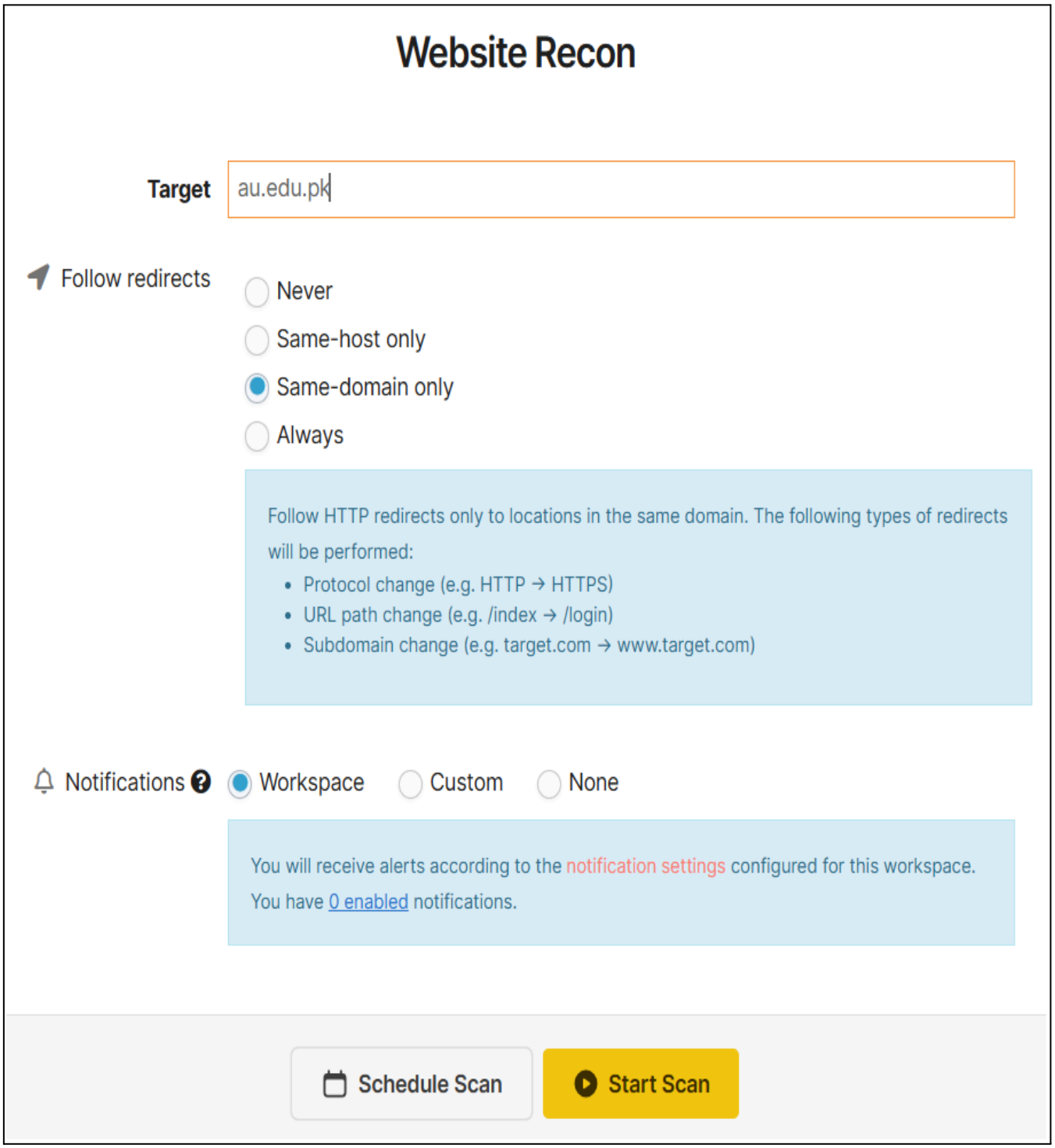


Figure 38: Selecting the Website Recon scan option and configuring the Scan Options.

- The scan took almost 2 minutes to complete and found one low level vulnerability.

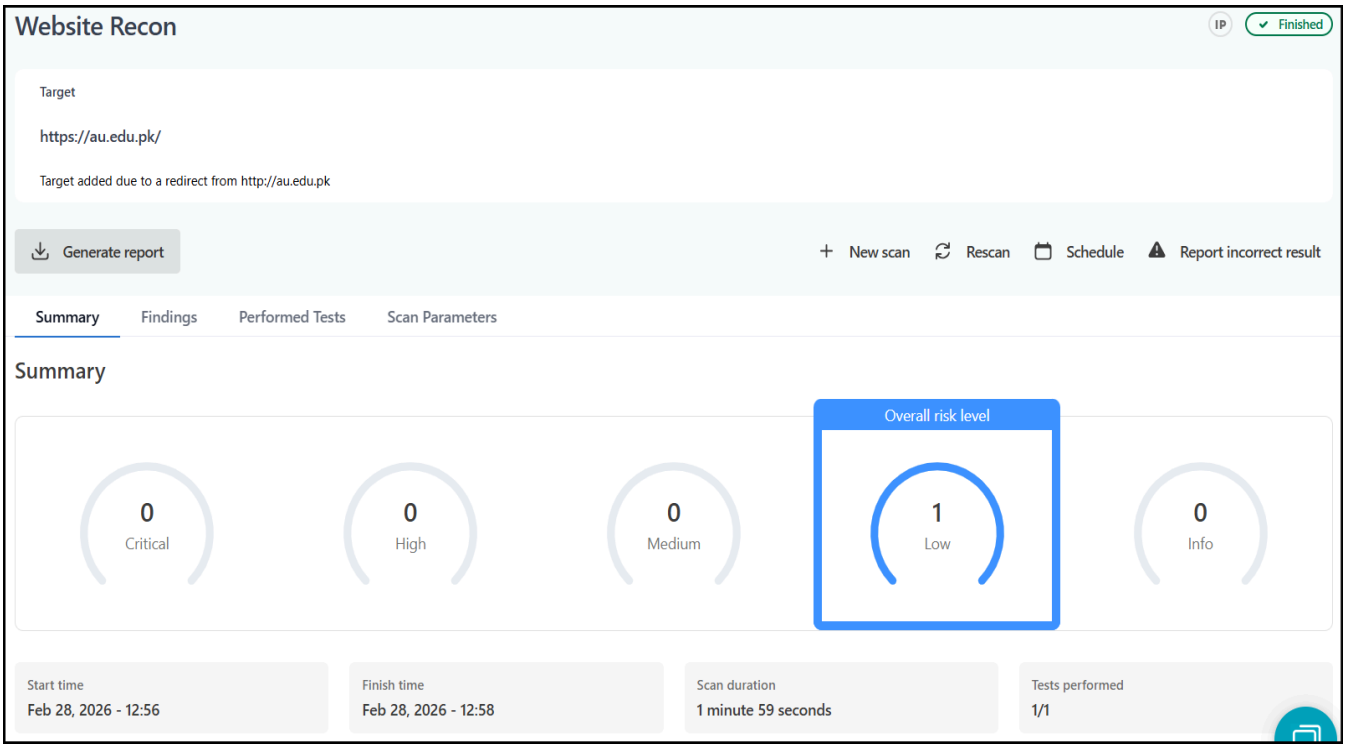


Figure 39: Pentest-Tools Website Recon Scan summary with 1 Low level finding and overall risk low.

- The low level finding turned out to be the info I needed, exposed web technologies.

Software / Version	Category
Magnific Popup	JavaScript libraries
Bootstrap	UI frameworks
microsoft-exchange	Miscellaneous
HTTP/3	Miscellaneous
jQuery 3.7.1	JavaScript libraries
jQuery UI	JavaScript libraries
Microsoft ASP.NET	Web frameworks
Cloudflare	CDN
WOW	JavaScript frameworks, Web frameworks, JavaScript graphics
Plesk	Hosting panels
HSTS	Security

Figure 40: Exposed Web application technologies as detected by the Pentest-Tools.

- And Once again I found another IPv4 Address being associated with the target.

Figure 41: Source IP Address being associated with the website's URL.

7.8. Task 8: Email Infrastructure Analysis

Here is the explanation for the Email Delivery Backend Procedures:

- **SMTP Role**:
  - It stands for Simple Mail Transfer Protocol (SMTP) and runs on port 25.
  - It is used to send emails from a client to a server and between mail servers.
  - It handles message transfer, queuing, and error reporting.
- **DNS MX Records**
  - The Mail Exchange (MX) records are present/stored in the DNS information.
  - They specify which MX servers are responsible for receiving mails for a domain.
  - When sending an email to someone, the sending server queries DNS.
  - This query is for the recipient domain's MX records to find the target server.

Here is how the phishing exploits this information/working:

- Attackers spoof the `From` address to appear legitimate.
  - They can spoof it by using similar domains or display names.
  - Common examples like `nricosoft` instead of the Microsoft emails.
- They may exploit misconfigured or use compromised servers to send bulk emails.
- They use multiple different techniques for exploiting/phishing such as:
  - Domain spoofing
  - Lookalike domains
  - Leveraging weak SPF/DKIM/DMARC policies

Here is the role of reconnaissance in all of this:

- Attackers gather information (email addresses, naming patterns, organizational structure) through OSINT, social media, or data breaches.
- This enables targeted spear-phishing campaigns with personalized content, increasing credibility and success rate.

Let me explain how email sending works in 2 different scenarios:

- **From @gmail.com to @gmail.com**
  - The sender's client sends via SMTP to Gmail's outgoing server.
  - Since both sender and recipient are on the same domain:
    - The email is routed internally within Gmail's infrastructure
    - Hence NO external DNS lookup needed.
  - Email is delivered directly to the recipient's inbox (subject to spam filters).
- **From @yahoo.com to @gmail.com**
  - The Sender's client sends via SMTP to Yahoo's outgoing server.
  - Yahoo server queries DNS for `gmail.com` MX records
  - This is done to obtain Gmail's mail server addresses.
  - Yahoo server establishes an SMTP connection with that Gmail server.
  - And finally it transfers the email.
  - Gmail then delivers it to the recipient's mailbox.

7.9. Task 9: Mapping to Cyber Kill Chain

All my findings fall under the **Reconnaissance** phase, where an attacker passively and actively gathers intelligence. This data feeds into subsequent phases:

- **Weaponization**:
  - Using discovered email addresses, naming conventions, and software versions
  - This helps to craft targeted phishing emails or prepare exploits.
- **Delivery:**
  - Exploiting missing DMARC records and understanding SMTP to spoof emails.
  - Sending spear-phishing via compromised servers or lookalike domains.
- **Exploitation:**

  - Targeting exposed cPanel/WHM/webmail ports or vulnerable subdomains.
  - or just performing some credential brute-forcing or vulnerability exploitation.
- **Installation / C2 / Actions:** If successful, attackers could install backdoors, establish command & control, and exfiltrate data.

Here are the next steps that can be done by using Collected Data:

- Conduct **scanning** (active recon) on discovered IPs/subdomains for live services.
- Launch **phishing campaigns** using gathered email addresses and the lack of DMARC.
- Attempt **exploitation** of identified services via known vulnerabilities or brute-force.
- Use **metadata** (authors, software) to tailor social engineering or find related exploits.

7.10. Task 10: Security Perspective (Defensive Thinking)

7.10.1. How Organizations Can Reduce OSINT Exposure

- Restrict public access to internal directories and files (e.g., block directory indexing).
- Implement `robots.txt` to prevent search engines from indexing sensitive pages.
- Educate employees on safe public data sharing (social media, documents).
- Regularly audit and remove exposed documents, credentials, or metadata.
- Use subdomain take over prevention and monitor for unintentional leaks.

7.10.2. How CIA Triad Relates to Reconnaissance Risks

- **Confidentiality**: Reconnaissance exposes confidential data (emails, file metadata, server versions), breaking confidentiality before an attack even begins.
- **Integrity**: Gathered intel can be used to craft convincing phishing, leading to data manipulation or unauthorized changes.
- **Availability**: Recon may reveal vulnerable services; if exploited, could lead to DoS or system downtime.

7.10.3. Controls to Prevent Intelligence Leakage

- **Technical Controls**: Web application firewalls (WAF), access controls, file permissions, disabling directory listing, and proper DNS configuration (SPF/DKIM/DMARC).
- **Administrative Controls**: Security policies, employee training, data classification, and regular security audits.
- **Physical Controls**: Restrict physical access to servers and network infrastructure.

8. Learning Reflection

8.1. What I Learned from This Assignment

This assignment provided me with hands-on experience in passive reconnaissance, demonstrating how much sensitive information organizations unintentionally expose. I learned to use various OSINT tools and techniques including Google dorking operators, metadata extraction tools (MW Metadata, Exif.tools), Shodan for infrastructure mapping, Netcraft for security header analysis, and automated recon platforms like Pentest-Tools. I discovered that even without active scanning, an attacker can gather emails, subdomains, open ports, software versions, and organizational patterns; all from publicly available sources. The exercise revealed how missing security controls like DMARC records and exposed directories create significant risk.

8.2. Reconnaissance Builds Foundation of Penetration Testing

Reconnaissance is the bedrock of any penetration test. Without proper recon, testing becomes blind and inefficient. The information gathered during this phase determines the entire attack surface; identifying which systems exist, what services run on them, who the users are, and what technologies are in use. This intelligence allows penetration testers to:

- Focus efforts on high-value targets
- Craft realistic phishing simulations using real employee data
- Select appropriate exploits based on discovered software versions
- Map network infrastructure through subdomain discovery
- Prioritize vulnerabilities based on exposed services

In the Cyber Kill Chain, reconnaissance feeds directly into weaponization and delivery. Poor recon means missed vulnerabilities and wasted effort.

8.3. How I Will Use These Skills as a Cybersecurity Professional

As a future cybersecurity professional, these reconnaissance skills will be essential for both offensive and defensive roles. On the offensive side (penetration testing), I will use OSINT techniques to simulate real-world attackers and identify weaknesses before they are exploited. On the defensive side (blue team), I will apply this knowledge to:

- Audit my organization's public footprint
- Implement controls to reduce OSINT exposure
- Educate colleagues about safe data sharing
- Monitor for unintentional data leaks
- Strengthen email security (SPF/DKIM/DMARC)

These skills will help me think like an attacker while defending like a guardian. The core mindset of an effective cybersecurity professional.

THE END